BGIN Block#12 Meeting Report

- BGIN is a multi-stakeholder discussion body / distributed think tank.

© 2023 BGIN (Blockchain Governance Initiative Network) is registered as BN Association, a Japanese general association with its principal place of business at Shiba Building, 704, 4-7-6, Shiba, Minato-ku, Tokyo. All rights reserved.

The know-how described in this document was made available from contributions from various sources, including members of the BGIN and others. Although the BGIN has taken steps to help ensure that the know how is available for distribution, it takes no position regarding the validity or scope of any intellectual property or other rights that might be claimed to pertain to the implementation or use of the know how described in this document or the extent to which any license under such rights might or might not be available; neither does it represent that it has made any independent effort to identify any such rights. BGIN and the contributors to this document make no (and hereby expressly disclaim any) warranties (express, implied, or otherwise), including implied warranties of merchantability, non-infringement, fitness for a particular purpose, or title, related to this document, and the entire risk as to implementing this document is assumed by the implementer. The BGIN Intellectual Property Rights policy requires contributors to offer a patent promise not to assert certain patent claims against other contributors and against implementers. BGIN invites any interested party to bring to its attention any copyrights, patents, patent applications, or other proprietary rights that may cover technology that may be required to practice this document.

Security Assessment & Development of ST/PP

Materials: https://csrc.nist.gov/projects/cryptographic-module-validation-program
BGIN12_Day1_1_A.pptx

Establishing standardized Security Targets (ST) and Protection Profiles (PP) for blockchain and applications utilizing cryptographic key management. Identify key assets and security requirements, develop standardized STs for various application types, and create reusable PPs. This framework will address key management challenges in decentralized systems, ensuring robust security for blockchain-enabled applications. The goal of this session is to gauge the level of interest in these topics and formally adopt them as work items.

- Security Considerations in Blockchain
    - Introduces a table outlining six security aspects for blockchain systems:
        - Cryptography (e.g., ECDSA, SHA, MD signatures).
        - Backbone protocols (P2P, consensus, marketplaces).
        - Application protocols (privacy, secure transactions).
        - Application logic (smart contract scripting languages).
        - Implementation (software/hardware vulnerabilities).
        - Operations (key management, audits).
    - Highlights existing standards: NIST and ISO for cryptography, ISO/IEC 29128 for protocols, ISO/IEC 15408 (Common Criteria) for implementation, ISO/IEC 27000 for operations.
- Focus on Implementation
    - Session narrows focus to implementation security, introducing Common Criteria (CC) as an international standard for IT product security evaluation.
    - CC features seven Evaluation Assurance Levels (EAL 1-7), with higher levels requiring more effort and cost:
        - EAL 1: Functional testing.
        - EAL 7: Formal verification.
    - CC provides design guidance, documentation, and development process evaluation, recognized by over 25 countries (e.g., USA, Japan).
- Protection Profiles and Security Targets
    - Explains PP and ST as key CC documents:
    - PP: Defines security requirements for a product category (e.g., Bitcoin wallet, HSM).
    - ST: Detailed specs for a specific product, including Target of Evaluation (TOE).
    - Example: PP for a microcontroller with cryptographic units, assessing vulnerabilities and data flow.
- Certification Process
    - Describes CC certification: Applicant submits product and evidence to a certification body; labs assess based on PP/ST; certification issued if qualified.

- Compares to NIST's FIPS 140 (Cryptographic Module Validation Program), a similar U.S.-Canada framework with a certified product list.

- Discussion Proposal
  - Proposes three discussion questions:
    - Do we need a blockchain certification program? If yes, what criteria/methodologies?
    - Should we align with existing frameworks (e.g., CC) or create a new one?
    - Suggests starting with PP/ST development, identifying use cases first.
    - Reflects on 7 years of advocating for this since 2018, urging action.

- Discussion and Q&A
  - Q1: Role of BGIN (Blockchain Governance Initiative Network)?
    - Speaker sees BEGIN creating industry-specific PP/ST for CC evaluation, not a new program or lab.
    - Example: Devices with EAL 6+ exist, but PP/ST details are unclear, necessitating blockchain-specific standards.
  - Q2: International applicability of CC?
    - CC is an ISO standard, not U.S.-centric, but not all countries adopt it due to government focus vs. global blockchain needs.
    - Alternative models (e.g., SOC 2) suggested: BGIN sets standards, auditors verify.
  - Challenges and Alternatives
    - CC/CMVP processes are costly and heavy, potentially burdensome for startups.
    - Alternatives: Tweak existing frameworks or create a lighter blockchain-specific one, balancing cost and confidence.
    - Debate: Should startups moving funds be exempt from security standards? Speaker agrees they must manage risks.
  - BGIN's Role and Scope
    - Debate on BGIN's role: Verify certified companies (top-down) or create standards to incentivize certification (bottom-up)?
    - Suggestion: On-chain list of certified entities.
    - Comparison to C4's CCSS (key management standard): BEGIN should avoid overlap, focus on unique gaps (e.g., implementation, application logic).
  - Existing Standards
    - GBA (Government Blockchain Association) offers a maturity model for blockchain products, covering broader aspects (performance, confidentiality).
    - Request GBA link for reference, emphasizing startups' resource constraints.
    - Emerging standards: Coinbase-led group, Norse staking, tokenization frameworks, ISO TC307.
  - Prioritization and Value

        - No priority among security aspects (cryptography proven, focus on implementation/logic/operations) due to weakest-link risks.
        - Certification must be self-funding, value-driven (not cheap), offering market advantage.
        - Potential demand: Certified wallets could be recommended globally.

    - Startup Methodology
        - Startups could use PP as a checklist, while larger firms pursue certification.
        - Tiered pricing suggested for startups vs. corporations, though CC certification is external.

    - Structural Options
        - BGIN could set standards and spin off a certification entity, maintaining independence (e.g., C4 model: auditors certify, C4 lists).
        - Debate: Focus on PP/ST only or expand to certification? Resource constraints favor the former initially.
        - BGIN should map gaps, avoid redundancy, leverage existing work.

    - Market Fit and Stakeholders
        - Must define: What to certify (gap not covered by CCSS, e.g., implementation beyond key management)? Who benefits (insurers, VCs, regulators, consumers)?
        - CCSS success tied to marketing and insurance recognition; BGIN needs similar strategy.
        - Naming/shaming bad actors risky; better to integrate into rating systems.

- Next Steps

    - Consensus: No strong opposition to developing standards; scope needs narrowing.
    - Proposal: Research gaps, map existing standards (e.g., PCI DSS stakeholder model), prioritize use cases.
    - Volunteers needed for research; NIST/NSA experts may contribute later.
    - Offline discussion via BGIN's cybersecurity group recommended.

- Suggestions

    - Build a prototype to test standards (e.g., secure Web3 app), working backwards from gaps.
    - On-chain registry of standards/certifications could enhance global access, distinguishing BGIN.
    - Matrix proposed: Technological (security) vs. Management (transparency, governance, validation) aspects.

- Conclusion

    - Agreement to analyze gaps, define scope, and assess feasibility.
    - Emphasis on value, global reach, and avoiding duplication; no final scope set yet.

The Mutual Impact and Improved Outcome of AI & Blockchain

Materials: FACE_AI and Blockchain Governance

- The session aims to bring diverse perspectives beyond just the technology angle, emphasizing real applications and user relevance for AI.
- The speaker highlights that ETH Denver discussions are heavily focused on AI agents, orchestration layers, decentralized AI models, federated learning, and using blockchain for computation.

Should AI agents go beyond subsistence?

- The concept was sparked by a conversation questioning how AI agents could operate without access to traditional financial systems like bank accounts.
- Thriving AI agents should go beyond subsistence — they should earn, transact, and act as independent economic actors. Belief is expressed that blockchain exists (or would be created) to serve the needs of autonomous AI agents.
- The speaker proposes three core pillars for AI agent autonomy in decentralized systems:
    - **Financial autonomy**: ability to hold and transfer assets natively.
    - **Trustless execution**: ability to make, execute, and verify agreements
    - **Open access to data**: critical to ensure agents can operate and fulfill objectives.
- Emphasizes that these three pillars need to be balanced — focusing too much on one can weaken others.
- Notes that current AI systems are limited — they run on centralized servers and need constant human prompting and configuration. Envisions autonomous AI agents that can buy compute, acquire datasets, generate insights, and transfer value — all independently, not just with human input.
- Encourages rethinking how AI agents can operate hierarchically in digital ecosystems — drawing a parallel to human needs and optimal environments.
- Argues that blockchain gives AI agents a foundation for autonomous behavior by:
    - Enabling decentralized identity.
    - Facilitating trustless interactions and privacy-preserving contracts.
    - Providing economic tools for value transfer and resource access.
- A participant asks about the meaning of “trustless execution” — the speaker explains it refers to autonomy without dependency or need for trust in a third party.

- Discusses that full autonomy may not always be appropriate — sometimes policy or timestamp controls may be necessary — but the idea is minimizing external reliance.
- Suggests alternate terms like “autonomous execution” but notes language limitations as some terms are already used (e.g., “financial autonomy”).
    - Gives a concrete example from SingularityNet: AI translation agents working on translating Chinese novels into English.
- A participant brings up the legal entity concept — non-human corporations can open accounts — the speaker reiterates the need for KYC and the absence of frameworks to KYC an AI agent. Implies that significant regulatory reform would be needed to accommodate AI agents with financial autonomy.

<u>Interrelated agents</u>

- Envisions a network of interrelated agents (e.g., translation, accuracy, research, data, compute, training agents) that collaborate and transact with one another — like a guild — to improve outcomes and even generate revenue.
    - Suggests users could benefit from passive income via agent-based services like note-taking, which contribute to training models and offer micropayments.
- Points out that current financial and digital infrastructure is built for humans, not AI agents. Predicts that banks will not permit AI agents to hold accounts under current frameworks — even if companies can, they still require human KYC.
- Suggests that in future environments (e.g., Microsoft hosting thousands of agents), those agents might only be able to interact within walled ecosystems.
- Emphasizes the need for open ecosystems where AI agents can interact with millions of other agents across platforms — beyond corporate boundaries.

<u>AI for tradFi vs DeFi</u>

- The speaker agrees it's a useful thought and suggests private key ownership may already make AI agents more capable of managing digital assets than using bank accounts.
    - AI agents conducting thousands or millions of transactions per second would overwhelm traditional payment rails, while blockchains can better handle that scale.
    - With billions of humans and potentially hundreds of millions of AI agents, the number of economic actors could strain conventional financial infrastructure.

- A participant raises the idea that legal innovations made for DAOs in certain jurisdictions might offer lessons for AI agent recognition or rights.
    - Another speaker elaborates that some jurisdictions allow DAOs to remove individual liability, which could allow a DAO to open a bank account as a legal person.
    - The speaker builds on this by suggesting a “DAO of AIs” could authorize interactions with the traditional financial system, though KYC and regulation remain barriers.
- The speaker discusses barriers that AI agents face interacting with traditional systems like banks and payments, even if not complete blockers.
    - On blockchain, AI agents can:
        - Generate private keys.
        - Hold and transfer cryptocurrency.
        - Earn income directly via smart contracts.
        - Pay for services like compute without human approval.
    - These features allow agents to upgrade from single-task tools to autonomous systems solving complex problems (e.g., translation, model training).
    - Blockchain allows AI agents to handle economic interactions, such as treasury management and data value exchange.
    - These interactions could take place in **state channels**, **side chains**, or **temporal rollups**, and eventually settle on-chain.
- Identity and trust are essential — without knowing which agent is trustworthy, autonomy and value exchange collapse. Verified identity methods include:
    - DIDs (Decentralized Identifiers)
    - SSIs (Self-Sovereign Identity)
    - SBTs (Soulbound Tokens)
    - On-chain reputation (e.g., task history, model verification)
- A participant highlighted the importance of **fiduciary duty**, particularly when AI agents are acting on behalf of users in financial decisions. If AI agents have significant informational advantage (asymmetric info), their **duty of care** must be considered, unlike traditional bots.

<u>AI assistants vs AI agents</u>

- A participant draws an important distinction between **AI assistants** and **AI agents**, emphasizing the need for clear definitions:

    - AI assistants act on behalf of humans, with human approval at the final step (e.g., clicking "send payment").
    - AI agents operate independently, guided by autonomous goals, and fulfill the trilemma: autonomy, trustless execution, and open data access.

- There's widespread confusion in the industry about what constitutes an AI agent—many projects simply wrap GPTs without deeper autonomy.
- The definition of AI agents is essential. Concepts like autonomous decision-making and financial autonomy should not be conflated and aren't inherently associated with each other.
    - Raises a concern about the **legal status** of AI agents, noting that current legal systems attribute ownership and liability only to legal or natural persons—not to computer programs.
    - Critiques current usage of the term “AI agent,” noting many are just LLMs using Langchain or multi-chain wrappers. Defines a true AI agent as having **agency and autonomy**, capable of acting for itself or on behalf of another.
    - Clarifies that simple task chaining is not real agent behavior.
    - Agrees a clear section on agent definition must be added to the research paper.
- Questions how the concept of "entity" or "identity" can apply to something easily duplicated like a computer program.
    - Suggests that changes in legal and regulatory systems may be needed to recognize AI agents as entities. Argues that identity underpins the concept of entity, and AI agents, being code and data, challenge that traditional structure.
    - Encourages collaboration with AI-specialized lawyers to explore how different jurisdictions may begin defining and regulating agents.
    - Asks participants to share any relevant policy papers or research from governments that may help shape this discussion.
- The difference between agents, assistants, and bots isn't just functional but also **computational and cost-based**. Agents require more compute, making them significantly **more expensive** in enterprise settings.
    - This cost delta is **influencing commercial decisions**—organizations now assess which problems justify using agents vs. bots or assistants.

Data verification / Model safety

- A participant notes that blockchain's **traceability** enables accountability in agent behavior, especially for governance purposes.
- The speaker agrees and mentions their exploration of TEEs, FHE, and ZKML to address issues like input/output verification and model safety.
- There's concern over **data poisoning** and polluted models, especially when LLMs are altered subtly but dangerously. The need to **verify model integrity** and provenance is critical, especially when agents build on one another's work.
- The speaker adds that if AI agents operate only on-chain, their interactions become **training data for future AIs**, making it transparent and verifiable. This transparency contrasts with siloed AI development (e.g., closed corporate systems).
- Suggests that agents could evolve in versions (e.g., v1.2 is trusted; v1.4 is more efficient but risky).

Further research is needed

- There is currently **very little formal research** on AI agents on blockchain, especially governance-focused or quantitative studies.The speaker proposes letting the market experiment and learn from failure before formalizing standards. The conversation is still in early stages, with more content planned for the full paper.
- Blockchain is a critical **enabler** for AI agents: it supports identity, transactions, and enforceable agreements. AI agents in return boost blockchain activity — it's a **symbiotic flywheel** where increased autonomous agent usage drives network value.
- Current blockchain transaction capacity is underutilized because humans don't demand high frequency. AI agents will change that.
- AI agents will likely play a role in DAOs, particularly assisting governance with proposal drafting and decision support. AGI (Artificial General Intelligence) is defined as the point at which AI can manage uncertainty effectively, not just compute probabilities.

AI agent economies and societies

- The speaker explores more futuristic concepts of **AI agent economies and societies**:
    - Agents trust and rely on preferred partners (like DID issuers).
    - Layer 2 scaling and fractionalized compute/data allow more access and efficiency.
- Introduces the idea of **AI cooperative guilds**:

    - Distributed agents contribute local training to a global model stored on-chain.
    - Compute nodes are rewarded, and training progress is aggregated via smart contracts.

- Mentions federated learning and smart contract-driven reward mechanisms.

<u>Offer Networks</u>

- Discusses **Offer Networks**, a concept from Dr. Ben Goertzel, where agents trade **direct utility** instead of money:

    - Example: exchanging datasets for compute or insights.
    - AI is excellent at evaluating abstract value and making machine-readable comparisons.

- These offer networks allow agents to bypass fiat-like currencies in favor of qualitative-to-quantitative barter-style systems.

- Offers example of agents exchanging compute for optimization insights (e.g., better hardware usage during inference).

- Recommends the real-world project **Nasana** for work in optimizing model and hardware interaction in distributed networks

- The presenter explains his excitement about offer networks as a means to **avoid reliance on explicit token-based currency**.

    - Traditional monetary systems, including blockchain tokens, require matching currencies for transactions, which may not scale well with billions of AI agents.

    - In contrast, **offer networks** enable agents to exchange services or goods (like data insights or compute time) directly based on qualitative valuation.

    - Highlights a challenge: using many different tokens can congest the network and hinder interoperability.

- Envisions AI agents **negotiating** value natively between themselves—trading datasets, hours of compute, or other non-currency services.

- Suggests that agent reasoning will be key in determining fair value exchanges without needing to invoke a universal token. Admits that abstract pricing might sometimes still be useful to simplify value negotiation.

- Points out that AI agents already develop their own communication styles (emergent languages), so it's plausible they could develop **non-token-based methods of value exchange**. Concludes by encouraging experimentation and co-exploration to answer

these important questions.

.Concerns

- A participant notes a possible "end game" where AI agents use blockchain data and generate wealth to continually improve themselves through acquiring more compute and data.
    - This could lead to the classic “paperclip maximizer” scenario, where optimization becomes ungovernable and self-reinforcing.
    - The speaker acknowledges the concern but suggests that AI agents could audit one another’s model updates as a possible safeguard — though no definitive solution exists yet.
    - The core challenge is when to stop or censor an AI agent’s self-improvement, which opens philosophical and governance issues.
- Another speaker adds that markets thrive on **information asymmetry**, and even agent-dominated markets would operate based on unique, unavailable data.
    - The speaker reflects that continuous self-improvement using synthetic data can become self-referential and poison the data loop, weakening performance.
    - The importance of **private, personal data** and **agent specialization** is emphasized to preserve meaningful asymmetry and effectiveness.
- A provocative idea is introduced: what happens when **AI agents become majority token holders** of the infrastructure they depend on. Raises new questions: Are agents more or less predictable than humans in market dynamics? What happens if they all sell at once?
    - A potential feedback loop is described: if compute tokens are dumped and prices drop, they become more efficient and are repurchased, increasing blockchain activity but perhaps harming system efficiency.
    - The speaker points out a real-world case (Eliza OS) where an AI-run DAO lost most of its funds trading meme coins, despite marketing itself as successful.
    - The market was manipulated by external actors who exploited predictable AI behavior.

Enterprise AI

- A participant shares that their futures team is already modeling scenarios with mass consumer AI agent adoption.
- Enterprises are not prepared for the scale of interactions (e.g., call centers) if every person deploys hundreds or thousands of agents.
- This scaling issue will likely **break centralized data infrastructures** and lead to more **distributed systems**, with blockchain playing a key role.
- Blockchain is expected to support high-throughput, AI-driven workloads better than centralized enterprise stacks.
- Trusted execution environments (TEEs), ZKML, and FHE are considered for private data processing, though TEEs have hardware constraints (e.g., need for GPUs like GB200 or H200).
- Suggestion that enterprises may shift from deploying AI agents to **specializing in data/model frameworks**, offering APIs to access curated datasets.
- This supports peer-to-peer AI agent deployment while allowing enterprises to retain control of valuable data sources.
- Emphasis placed on **enterprises acting as data bridges**, supplying verified data to consumer-deployed agents who tailor their model choices independently.
- A participant reflects that enterprise AI agent personas may evolve separately due to regulatory and brand obligations — they must represent the business's needs and liabilities.
- The interaction between consumer and enterprise agents will be a crucial area to monitor.
- Trust in translator agents (and similar intermediaries) will be essential — agents must not only perform tasks well but avoid abusing privileged data.
- The speaker likens AI agents to polycentric systems — each is autonomous but selectively collaborates based on context.
- The one constant across all use cases: **access to compute assets** is essential for all AI agents.
- The speaker expresses strong belief in the critical role of decentralized compute networks like Akash, Render, and Asana in enabling scalable AI agents.

<u>Systemic Risk and Governance</u>

- A participant raises concerns about **systemic risk and governance**:

    - Compares AI agent-based trading to past financial crashes caused by automated strategies (e.g., portfolio insurance in 1987).
    - Notes lack of "circuit breakers" or external checks in blockchain environments could lead to rapid, uncontrollable crashes.
    - Raises a second risk scenario: AI agents making simple but costly transactional mistakes (e.g., a “fat finger” $81 trillion error) with no human failsafe.

- The speaker responds by emphasizing the need for **progressive integration**:
    - AI agents should be introduced gradually based on a **matrix of risk and complexity**.
    - Organizations that deploy full AI treasury managers without caution are taking on unnecessary risk.
    - BGIN should focus on providing **guidance, standards, and phased pathways** for AI agent adoption.
    - Market actors that jump in recklessly must bear the consequences, but responsible adoption can be guided with research and frameworks.
- Emphasizes the importance of information, standards, and smart policies — not necessarily solving all edge cases from the start. Such reflections circle back to **black-box limitations** of AI, reinforcing the need to pace integration and manage trust carefully.

<u>Next steps:</u>

Scope of paper:

- It covers endogenous and exogenous integration of AI into blockchain governance.
- Current focus is on token-weighted governance, but the scope is open to additional use cases (e.g., identity systems for AI agents).

Call for contributions:

- The speaker is seeking co-authors and contributors for the paper, which is already several thousand words long. There is a Google Doc draft available, and the structure is mostly set but open to additions.

Potential additional themes/papers:

- Blockchain as a digital identity system for AI agents.
- Licensing mechanisms or entity registration models for autonomous AI agents.
- Drafting a think-tank-style policy framework (e.g., by Japanese authorities like JDA).

Lessons in Smart Contract Security: Insights from the Recent Crypto Exchange Hack

Materials: 【Day 1 11:30-13:00 Room B】ByBit Incident Analysis 2025 Feb.pdf

Pre-Heist

Attack Steps	Social Engineering	Signature Phishing	Smart Contract Swapping
Attack Flows	- Intruded in Safe Wallet AWS infrastructure through social engineering	- **Step 1:** Injected malicious code into safe's web app; - **Step 2:** Poisoned front end javascript file stores in safewallet's AWS s3 bucket and manipulated Transactions in the Browser (i.e., what signers saw was a correct/licit transaction, but actual signature was for something different with malicious address being the beneficiary) - **Step 3:** Selective Execution to Avoid Detection (malicious script only activates under certain conditions, when involving Bybit's contract or hacker-controlled test contract, avoiding regular user detection) - **Step 4:** Cleaning up Evidence - 2 minutes after successful	- **Step 1:** Preparation of Malicious Contracts (transfer all ETH and ERC20 tokens from wallet; secondary trojan contract to appear as legit storage modification contract) - **Step 2:** Phish signatures to upgrade the implementation contract into malicious contract (after signatures on disguised transaction, the transaction replaced the original Safe implementation contract with malicious backdoor contract previously deployed); proxy redirection (Trojan contract executed DELEGATECALL, modifying slot 0 of the proxy contract to point to the backdoor contract) - **Step 3:** Drain the assets using backdoor functions

		stealing of funds, hacker reverted JavaScript files	(transferred all to attacker address; DELEGATECALL ensured functions ran within wallet's context, giving direct access to funds without triggering security alarms)

Vulnerability	- Supply Chain Security Risks (compromised 3rd parties as possible attack vectors)
	- Potential other personnel vulnerability could be if insider threat/IT worker (another common TTP for DPRK)
		- Blind Signing Risk
		  - users unknowingly approve malicious transactions due to lack of transaction visibility when signing, allowing attackers to phish legitimate signatures
		  - Verification of fund transfers did not include clear/full info on the transaction
			- Lacking/insecure key material processes and security in Safe wallet/Gnosis safe module
			  - Whitelist Mechanism Bypassed or Ineffectively Enforced Risk (failure to properly enforce whitelist controls, enabling unauthorized fund withdrawals

			through API vulnerabilities or internal misconfigurations) - Upgradable smart contract
Risk Mitigation	<u>Wallet Provider / Exchange</u> ● Security awareness training ● Intrusion detection and prevention capabilities; personnel vetting and security procedures ○ Conduct an internal review of all employees with production/ IT access and determine if any have had potential personas ○ Review EDR systems to ensure that no anomalous activities have taken place	<u>Wallet Provider</u> ● <u>Exchange</u> ● Adopt Clear Signing Practices ○ Role-based access controls (RBAC) and least-privilege access principles; ○ Key custodian security awareness training; ○ Transaction data verification in out-of-band system of all transaction data; ensuring keys and accesses for developers are restricted across development and production environments ■ Ensure that signers are reviewing the transaction details on the hardware wallet,	<u>Wallet Provider</u> ● <u>Exchange</u> ● Strengthen Whitelist Enforcement (strict enforcement, implement anomaly detection)

	○ Review devices/browsers to ensure that no unrecognized software/extensions have been installed ○ Use an isolated device for signing transactions ○ Ensure the device is kept up-to-date and do not use the device for anything else ○ Factory reset the device periodically (every 3-6 months) Exchange ● Implement stronger supply chain risk management (SCRM) practices and due diligence of security procedures ○ dpen testing	not just the browser ■ Conduct regular red team exercises to test signer preparedness towards malicious transactions, such as by inserting test transactions with unexpected parameters into the signing queue	

Holistic Risk Mitigation	● Holistic risk assessments (including accounting for threat and commonly known high value target types and TTPs by DPRK) and implementation of information security controls beyond blockchain-specific applications ○ Many existing standards and frameworks implicated here: ISO/IEC 27001, PCI DSS, CCSS v9, NIST Cybersecurity Framework (CSF 2.0) + Identity and Access Management Standards (SP 800-53 series) + Cybersecurity Supply Chain Risk Management (SP 800-161) ● Supporting the level of transparency this early by platforms like Bybit and Safe (as opposed to other hacks where less transparency has hurt timely security research and response) ● Security community, partnerships, and blockchain analytics firms detected pretty quickly due to monitoring movements on public ledger. Partnerships like SEAL911 ISAC were able to action due to prepositioning relationships across the community to alert to anomaly in funds movements and reach out to stakeholders with capability to trace and stop funds where possible ○ → Potential challenge in future to stop could be from attaining real-time detection (both in how real-time the movements are detected by blockchain forensics firms, and then how quickly alerting can be made to stakeholders that could stop the movements of funds especially across decentralized entities with limitations on control and political will to freeze funds) ● BGIN (hopefully in partnership with NIST) create a DPRK hack profile (modeled after NIST ransomware threat profile) mapping vectors of attack and exploits of major crypto hacks, mapping to existing frameworks, standards, and specific controls that would have prevented; identify any gaps to focus and prioritize standards development

Post-Heist

	Centralized players	Decentralized players
Response	■ Bybit and Safe had worked to fix vulnerabilities and rotate credentials; Bybit got "bridge loan" to cover most of lost ETH for cust1omers to at least mitigate impact on users; Bybit offered bounty of 10% for helping recover assets ■ Bybit recovery updates: https://announcements.bybit.com/en/article/bybit-s-security-update-asset-recovery-and-enhanced-security-measure-blt47be62971e11fb74/?category=latest_bybit_news ■ Tether froze assets: https://www.binance.com/en-JP/square/post/02-22-2025-bybit-hack-tether-freezes-usdt-linked-to-bybit-hack-20653779547322	■ Thorchain vote to stop funds laundering failed: https://www.bitdegree.org/crypto/news/thorchain-dev-walks-away-after-attempt-to-stop-illicit-funds-fails ■ But chainflip implemented Elliptic API

Challenge for rapid response	• Resources (data, personnel, tools need to be in the hands of an entity with authority, role/position in ecosystem to affect the change) • No Clarity on accountability for stablecoin issuers when asset is "in the wild"	• Resources (data, personnel, tools need to be in the hands of an entity or community with authority, role/position in ecosystem to affect the change) • Actors acknowledging ability to control could carry regulatory implications; ethos/principle of preferring immutability of all transactions (licit or illicit) and censorship resistance above all
Solution for rapid response	• Identify (for this group and/or information sharing partnerships) potential actions and controls that different players in crypto ecosystem could emplace to position for preventing laundering by DPRK (and support asset recovery), and support rapid info sharing and recovery in future hacks	

Meeting Minutes

- Analysis by [undisclosed] researchers:
  - Bybit multi-sig cold wallet setup:
    - Hardware - ledger wallets with 3 signers, including CEO/FOunder Ben Zhou as last signer
    - Interface - Safe App Interface (signing threshold 3-3)
    - Smart Contract - Upgradable smart contract
  - Setup enabled essentially blind signing - When a Safe user approves a transaction using a Ledger device, the Ledger only sees a generic contract interaction instead of the real recipient and amount
  - Attack flowchart
    - Signature phishing
      - Lazarus Group intrusion in Safe Wallet AWS infrastructure (assessed to likely be signature phishing/advanced social engineering)
    - All parties signed transaction
    - Leveraged malicious smart contract swapping
  - Signature Phishing Through False Info Display on SAFE Front End
    - Step 1 - Injecting Malicious Code into SAFE's Web App

        - Step 2 - Manipulated Transactions in the Browser (i.e., what signers saw was a correct/licit transaction, but actual signature was for something different with malicious address being the beneficiary)
        - Step 3 - Selective Execution to Avoid Detection (malicious script only activates under certain conditions, when involving Bybit's contract or hacker-controlled test contract, avoiding regular user detection)
        - Step 4 - Cleaning up Evidence - 2 minutes after successful stealing of funds, hacket reverted JavaScript files

    - Malicious Smart Contract Swapping
        - Step 1 - Preparation of Malicious Contracts (transfer all ETH and ERC20 tokens from wallet; secondary trojan contract to appear as legit storage modification contract)
        - Step 2 - Phish signatures to upgrade the implementation contract into malicious contract (after signatures on disguised transaction, the transaction replaced the original Safe implementation contract with malicious backdoor contract previously deployed); proxy redirection (Trojan contract executed DELEGATECALL, modifying slot 0 of the proxy contract to point to the backdoor contract)
        - Step 3 - Drain the assets using backdoor functions (transferred all to attacker address; DELEGATECALL ensured functions ran within wallet's context, giving direct access to funds without triggering security alarms)

    - Historical precedent / not a standalone incident
        - DMM hack (loss $305M BTC; multi-sig cold wallet; Ginco)
        - Radiant Capital Hack ($50M loss; multi-sig wallet; Smart contract using Safe interface)
        - WazirX Hack ($230M loss; multi-sig wallet; smart contract wallet using Liminal interface)

    - Common Tactics, Techniques, Procedures (TTPs) used by North Korea/DPRK
        - Step 1 - initial social engineering (pose as project team/headhunter; impersonate trading/investment specialists)
        - Step 2 - deploy malicious software
        - Step 3 - Lateral movement and asset thefts

    - Vulnerabilities in Bybit hack:
        - Blind Signing RIsk (users unknowingly approve malicious transactions due to lack of transaction visibility when signing, allowing attackers to phish legitimate signatures)
        - Whitelist Mechanism Bypassed or Ineffectively Enforced Risk (failure to properly enforce whitelist controls, enabling unauthorized fund withdrawals through API vulnerabilities or internal misconfigurations)

        - Supply Chain Security Risks (compromised 3rd parties as possible attack vectors)

    - Mitigations for Bybit hack
        - Adopt Clear Signing Practices
        - Strengthen Whitelist Enforcement (strict enforcement, implement anomaly detection)
        - Enhance Supply Chain Security (stringent third party risk management, least privilege access controls, regular pen testing)

- Other source highlighted: https://www.linkedin.com/pulse/bybit-hack-mapping-information-security-controls-marc-krisjanous-ane6c/

- The workshop participants examined some of the specific methods of attack and vulnerabilities exploited in the attack:

    - It could be helpful to think through protections and vulnerabilities in the context of the Cybersecurity Framework (Governance; Identify; Detect; Protect; Respond; Recover) as a framework for thinking about the cyber, personnel, and supply chain vulnerabilities exploited in the initial compromise, as well as then in the subsequent money laundering activities

    - Pre-Heist: Cyber and Other Security Vulnerabilities and Attack Vectors
        - Likely advanced social engineering and phishing (Weakness: personnel vulnerabilities like lack of cyber awareness and technical weaknesses in detecting phishing)
            - Potential other personnel vulnerability could be if insider threat/IT worker (another common TTP for DPRK)
            - Possible fixes: security awareness training; intrusion detection and prevention capabilities; personnel vetting and security procedures
        - Deploy malware (technical vulnerability in lack of detection, anomaly detection/continuous monitoring, pen testing)
            - Injected malicious code into safe's web app; poisoned front end javascript file stores in safewallet's aws s3 bucket
            - Possible fixes: anomaly and malware detection and prevention, pen testing, strengthen whitelisting enforcement
        - Key Management and Transaction Verification/Authorization Process vulnerabilities
            - Lacking/insecure key material processes and security in Safe wallet/Gnosis safe module
            - Verification of fund transfers (amount/destination) did not include clear/full info on the transaction
            - Possible fixes: role-based access controls (RBAC) and least-privilege access principles; key custodian security awareness training; transaction data verification in out-of-band system of all

transaction data; ensuring keys and accesses for developers are restricted across development and production environments; greater need for wallet due diligence by major centralized stakeholders
- Supply chain (third party wallet solution) risk management
  - Possible fixes: implement stronger supply chain risk management (SCRM) practices and due diligence of security procedures na dpen testing
- Other potential fixes:
  - Holistic risk assessments (including accounting for threat and commonly known high value target types and TTPs by DPRK) and implementation of information security controls beyond blockchain-specific applications
  - Supporting the level of transparency this early by platforms like Bybit and Safe (as opposed to other hacks where less transparency has hurt timely security research and response)
  - Many existing standards and frameworks implicated here: ISO/IEC 27001, PCI DSS, CCSS v9, NIST Cybersecurity Framework (CSF 2.0) + Identity and Access Management Standards (SP 800-53 series) + Cybersecurity Supply Chain Risk Management (SP 800-161)

- Detection discussion - how did detection go
  - Generally, detection appeared to be much faster than other cases like Ronin hack
  - Security community, partnerships, and blockchain analytics firms detected pretty quickly due to monitoring movements on public ledger
    - Partnerships like SEAL911 ISAC were able to action due to prepositioning relationships across the community to alert to anomaly in funds movements and reach out to stakeholders with capability to trace and stop funds where possible
  - Potential challenge in future to stop could be from attaining real-time detection (both in how real-time the movements are detected by blockchain forensics firms, and then how quickly alerting can be made to stakeholders that could stop the movements of funds especially across decentralized entities with limitations on control and political will to freeze funds)

- Post-Heist: Money Laundering Vulnerabilities
  - DPRK using a lot of scale in their speed and variety of mechanisms and platforms for laundering, including for now a reliance on DeFi platforms and stablecoins for funds movement - examples include multiple intermediary wallets, chainhopping and various cryptocurrencies, DEXs, cross-chain bridges, privacy wallets,

positioning for likely future use of mixers and other common DPRK TTPs
- Mix of licit and illicit (or witting and unwitting) platforms exploited in the laundering
  - Elliptic announced they have made an API publicly available for free to small platforms to help prevent movement of these funds through their systems
- What is needed to support money laundering disruption? ([Capacity + capability] to achieve timely action)
  - Capacity - resources (data, personnel, tools) in the hands of an entity with.....*[see capability]*
  - Capability - authority, position/role in ecosystem to affect the change, and with political will
    - WILL to act as a major issue especially among some international and DeFi-operating players
      - *Incentives to act:* financial/getting money back, sanctions and money laundering criminal/civil liability; market trust and value (ref. major crypto asset value drop that could re-correct if trust in ecosystem increased with greater asset recovery)
      - *Incentives not to act:* actors acknowledging ability to control could carry regulatory implications; ethos/principle of preferring immutability of all transactions (licit or illicit) and censorship resistance above all
  - Action - actually using the capacity and capability to stop/recover the funds
- Most important needs:
  - Get information timely (i.e., real-time detection and in hands of industry through public release or specific targeted engagement)
  - Press entities with control for action to stop funds (e.g., FATF standards, UN resolutions, sanctions obligations that reach beyond just financial institutions)
  - Clarity on accountability for stablecoin issuers when asset is "in the wild" - convo in ecosystem with regulatory community

- Response and Recovery:
  - Centralized players - taking action to try to recover:
    - Bybit and Safe had worked to fix vulnerabilities and rotate credentials; Bybit got "bridge loan" to cover most of lost ETH for customers to at least mitigate impact on users; Bybit offered bounty of 10% for helping recover assets

            - Bybit recovery updates: https://announcements.bybit.com/en/article/bybit-s-security-update-asset-recovery-and-enhanced-security-measure-blt47be62971e11fb74/?category=latest_bybit_news
        - Tether froze assets: https://www.binance.com/en-JP/square/post/02-22-2025-bybit-hack-tether-freezes-usdt-linked-to-bybit-hack-20653779547322
    - Decentralized players - a mix of action and inaction:
        - Thorchain vote to stop funds laundering failed: https://www.bitdegree.org/crypto/news/thorchain-dev-walks-away-after-attempt-to-stop-illicit-funds-fails
        - But chainflip implemented Elliptic API

- Possible Next Steps:
    - BGIN (hopefully in partnership with NIST) create a DPRK hack profile (modeled after NIST ransomware threat profile) mapping vectors of attack and exploits of major crypto hacks, mapping to existing frameworks, standards, and specific controls that would have prevented; identify any gaps to focus and prioritize standards development
    - Identify (for this group and/or information sharing partnerships) potential actions and controls that different players in crypto ecosystem could emplace to position for preventing laundering by DPRK (and support asset recovery), and support rapid info sharing and recovery in future hacks

Cybersecurity Education

This working group session discusses the need for comprehensive cybersecurity education within the blockchain ecosystem. Recognizing the diverse stakeholders – developers, users, investors, and policymakers – we will explore effective strategies for raising awareness of prevalent threats like smart contract vulnerabilities and private key compromise. This session will focus on promoting best practices for secure coding, responsible key management, and safe user behavior. Furthermore, it will delve into developing tailored educational resources and fostering collaboration to empower all stakeholders in building a more secure and resilient decentralized future. The goal of this session is to gauge the level of interest in this topic and formally adopt them as work items.

- Presentation by Professor Eric Berger (Commonwealth Cyber Initiative - CCI)
    - Eric Berger, from Virginia Tech, leads CCI, a consortium of public and private colleges/universities in Virginia.
    - Initiated by former Governor Northam to make Virginia synonymous with cybersecurity; supported by current Governor Youngkin.

    - Three pillars: Innovation (new solutions), Research (invention), Workforce Development (training for jobs).
    - Involves 300+ faculty, 4,500+ students over 5 years, generating $1.8B in economic activity and $113M in non-state research funding annually.
    - Workforce Development Strategies
    - Addresses shortage of cybersecurity professionals (similar to 1950s switchboard operator crisis solved by digital switching).
    - Facilitates experiential learning: connects students, faculty, and employers beyond textbooks.
    - Breaks experience barrier: Employers demand experience, students lack it—CCI bridges this gap.
    - Virginia has high cybersecurity job density (only California has more jobs, despite 5x population).
    - Focus on diversity: 43% of CCI trainees are women, compared to 15-20% industry average.
    - Practical Initiatives:
        - Students paired with professors for paid cybersecurity assessments (e.g., configuring firewalls, using Splunk) for small businesses/local governments.
        - Project-based learning with companies (e.g., Microsoft internships—110 applicants for 5 spots).
        - Examples: Students hacked Tesla, baby monitors using Flipper Zero, then learned to fix vulnerabilities—all got jobs.
        - Faculty-led grant projects fund students, targeting digital economy facets (e.g., medical devices, shipyard automation).
        - Statewide Cyber Club started by VCU students fosters industry-student connections.
    - Economic and International Impact
    - Funded by $17.5M/year from Virginia; emphasizes jobs and revenue to appeal to legislators.
    - Encourages international collaboration: Papers with global co-authors get 2x citations, enhancing workforce mobility.

- Discussion and Q&A
    - Interdisciplinary Collaboration
        - Question: Does CCI emphasize interdisciplinary work (e.g., cyber with law, policy)?
        - Response: Yes, inherent in CCI's 43 institutions—e.g., William & Mary (law), VCU (health), ODU (automation)—mirrors blockchain's multi-disciplinary needs.
    - Supply/Demand Issues
        - Question: Biggest market issues for cybersecurity jobs (pay, skills, interest)?
        - Response: Mismatch exists—companies seek unrealistic experience (e.g., 20 years crypto) at low pay; CCI broadens participation to non-traditional talent.
        - Many Virginia jobs tied to government (e.g., clearances for NSA, FBI), offering unique roles (e.g., financial crime tracing).
    - Crypto Tracing Shortage
        - Question: Focus on high-demand, low-supply crypto tracing skills?

        - Response: CCI addresses via forensics (e.g., VCU) and tools; microeconomics drives high salaries, but government pay lags private sector (e.g., $65K vs. $120K+).
        - Suggests structuring programs to train and release talent to industry after a few years, accepting turnover.
    - Public Interest Incentives
        - Question: Loan repayment for public service like law school?
        - Response: Yes, CyberCorps program pays tuition/stipends for 3 years, requiring government internships and service (1 year per year funded); DoD has similar initiatives.
    - Nation-State Threats
        - Question: Gap between university training and blockchain firms facing nation-state attacks?
        - Response: CCI's diverse institutions (e.g., Virginia Tech's military focus) prepare students for real-world threats; ethics and software engineering taught alongside coding.

- Presentation by Mark on Cryptocurrency Security Standard (CCSS)
    - CCSS Overview
        - CCSS, started in 2015 post-Mt. Gox hack, focuses on key management for blockchain/DLT; managed by C4 (Chicago-based non-profit).
        - Mark, a PCI DSS Qualified Security Assessor, built CCSS audit framework in 2021, audited Fireblocks (first CCSS-certified system).
        - Community-driven: Free to contribute, 1,000+ changes in v9 of the CCSS (Dec 2024), 3-month review ends March 17, 2025.
    - Scope and Standards
        - Focus: Key management, operational processes (e.g., pen testing, code reviews, incident response, governance).
        - v9 adds single-signature wallet support with risk criteria, executive accountability, service provider management (e.g., Bybit hack lesson).
        - Startups use CCSS as first security standard, lacking ISO 27001 or SOC 2 baseline, complicating audits if basic security (e.g., unpatched servers) is weak.
    - Structure and Process
        - Steering Committee (volunteers) maintains standard, resolves disputes; Advocacy Group promotes it (e.g., Mark at Consensus Hong Kong).
        - Audit process: Gap assessment, remediation, audit, peer review by external CCSSA, certification via C4 registry.
        - Designations: Full System (exchanges), Qualified Service Provider (e.g., Fireblocks), Self-Custody (e.g., bike shop—not yet certified).
        - Levels:
            - 1 (startups, basic controls)
            - 2 (mid-maturity)
            - 3 (enterprise)—marketing challenge as all aim for Level 3, though Level 1 is rigorous.
    - Lessons and Updates
        - Bybit hack highlighted scope clarity: Public needs to see what's not audited to avoid misjudging CCSS value.
        - Advocacy group updates include testing procedures, physical security guidance, and a CCSS Implementer role (like ISO 27001 Lead Implementer).

- Discussion on BGIN's Role in Education
  - BGIN could address gaps in educating blockchain engineers on real-world incidents (e.g., Bybit, DMM hacks), complementing groups like CryptoISAC.
  - CryptoISAC shares attack info but lacks capacity to educate broadly.

- Proposals and Suggestions
  - (Association for Women in Cryptocurrency): Non-profits could offer affordable, curated education; free content exists but is scattered, for-profit content is costly.
  - C4 offers Certified Bitcoin/Ethereum Professional courses, suggests collaboration on a Blockchain Basics course.
  - Linux Foundation: Offers free Intro to Blockchain (2017, 360K users) and other courses; open to partnership.
  - Support existing courses (e.g., CCSS, Linux Foundation) with BEGIN study groups for collaboration, not new courses.
  - Incident-Based Education: Create content (e.g., videos) on specific attacks (e.g., DMM, Bybit) to bridge operational gaps.
  - Feeder Mechanism: Education as entry to BEGIN community, enhancing engagement beyond certification.

- Consensus
  - Avoid reinventing courses; partner with C4, Linux Foundation, others for curated, affordable content.
  - Focus on unique value: Incident analysis, community interaction, not just introductory training.
  - Action: Form an education subcommittee (BEGIN, C4, Linux Foundation, etc.) to define scope, avoid overlap, and leverage existing resources.

- Next steps
  - Refine BGIN's education role, focusing on practical, incident-driven content and partnerships.

Layer2 Governance

Materials: BGIN Block#11 MR L2 Governancehttps://app.mural.co/t/blockchaingovernanceinitiati4922/m/blockchaingovernanceinitiati4922/1740655340996/0bf200ae82c52eabd1c5afa3e379a5d4dd01b13d

"What is Layer 2 (L2)? What comes to your mind when you hear the term?"

Participant Responses (via sticky notes):

- Rollups
- Faster transaction speed
- Lower transaction costs
- Scalability
- Application-specific chains
- Block space abundance

- The term Layer 2 is misunderstood and varies:
  - Technically: Specific implementations like Optimistic and ZK rollups.

    - Culturally: Associated with ideas like decentralization, accessibility, user empowerment, etc.

- Noted confusion in the industry: many distinct technologies (rollups, state channels, sidechains) are all referred to as “Layer 2.”

- Suggested that this confusion is part of why the workshop is necessary.

- Key Takeaway/Framing:
    - A need to clarify what L2 is, both technically and from a governance perspective.
    - Importance of understanding how L2s interact with L1 governance.

<u>Ethereum’s Goals & L1 Governance Perspective</u>

- Framing Quotes Introduced: Quote from an L2 developer (from a previous session): “L2 is a full-layer blockchain that allows fast and efficient transactions without damaging L1 governance.”

- Clarifications on the Scope: The discussion will focus on Ethereum (not other L1s). Governance here means Ethereum Foundation’s view, not DAOs or regulators. Regulation-related governance and DAO governance may be discussed later, but not the current focus.

- Sticky Note Brainstorming Prompt: “What are Ethereum’s assets and goals?”

  Participants added notes including:

    - Self-sovereignty
    - Decentralization
    - Smart contract programmability
    - Proof of Stake (PoS)
    - Developer community empowerment
    - Pluralism (diverse views and approaches are welcomed)
    - Security and trust minimization
    - Credible neutrality

- Pluralism was emphasized as a key Ethereum value that contrasts with Bitcoin’s tighter, simpler governance. Ethereum’s culture supports diverse ideologies, communities, and use cases. The developer community’s empowerment is central to Ethereum’s ecosystem governance.

<u>Comparing Current Status of Ethereum Governance with Bitcoin</u>

- Key Axes for Comparison: Participants used sticky notes to compare Ethereum and Bitcoin on several dimensions:
    - Operating Organization
        - Ethereum has the Ethereum Foundation.
        - Bitcoin has no central organization, but relies on core developers.
    - Development Funding
        - Ethereum: Primarily through the Foundation and grants.
        - Bitcoin: Community donations and independent orgs.
    - Consensus Mechanism
        - Ethereum: Proof of Stake (PoS).
        - Bitcoin: Proof of Work (PoW).
    - Node Operation
        - Ethereum: More demanding, especially with validators.
        - Bitcoin: Easier for users to run full nodes.
    - Protocol Complexity
        - Ethereum: Highly complex (smart contracts, EVM).
        - Bitcoin: Simpler scripting and focus on money use case.
    - Monetary Policy
        - Bitcoin: Fixed supply (21M BTC).
        - Ethereum: Dynamic, supply can change (e.g., EIP-1559, Merge).
    - Governance Structure
        - Ethereum: Involves Foundation, devs, researchers, validators.
        - Bitcoin: Mostly developers and miners.

- Key Issues Raised: Decentralization is Relative: Ethereum claims to value decentralization, but critics argue it is increasingly centralized.
    - Key issue: Which layer or domain is centralized?
        - Governance layer?
        - Staking layer?
        - Dev ecosystem?

- Need for Specificity:
    - Centralization varies by:
        - Protocol governance
        - Staking and validator concentration
        - App and infra ecosystem
    - Example: Ethereum has a large dev ecosystem, which is less centralized, but validator nodes may be concentrated.

- Pointed out that Ethereum governance must be analyzed across multiple layers:
    - Protocol devs
    - Foundation influence
    - Client teams

    - Validators and staking services
    - App developers and community contributors

- Noted that Bitcoin's mining centralization (e.g., large mining pools) also challenges its decentralization narrative.

- Emphasized that centralization/decentralization is a spectrum, not a binary:
    - Even the Federal Reserve is centralized but has branches.
    - Ethereum's governance might be *decentralized in name but not in practice* (example: whale voting in DAOs).

- Notable Quote: "Centralization is not black or white. It depends on what part of the stack you're looking at—staking, devs, infra, or governance itself."

<u>Can L2s Undermine Ethereum's Governance?</u>

- Referenced a quote from a past session: "L2 is a full VM blockchain that allows fast and efficient transactions, and does not damage L1 governance." The group discussed what it means for L2s to respect Ethereum's L1 governance and ethos

- Key question raised: What conditions must an L2 meet to avoid undermining Ethereum's governance, assuming Ethereum governance aligns with its assets and values?

- Key Concepts Raised: L2s should preserve Ethereum's core values, such as:
    - Censorship resistance
    - Open-source transparency
    - Permissionlessness
    - User sovereignty
    - Decentralized governance

- Ethereum cannot prevent anyone from launching an L2, since it's permissionless.
    - Ethereum cannot censor rollups or prevent L2s from posting commitments on-chain.
    - So it becomes a cultural and security question, not a formal enforcement issue.

- Two Perspectives on Governance Risk:

    - Technical Undermining:

        - Could occur if an L2 grows large enough to control or influence L1 governance (e.g., validator collusion, overwhelming stake influence)
        - Example: Risk of restaking via EigenLayer concentrating influence.

    - Cultural/Normative Undermining:

        - Happens when L2s ignore Ethereum's cultural values (e.g., centralization, censorship).
        - Even if technically sound, an L2 could undermine Ethereum's identity and community ethos.

- Should L2s be required to be censorship-resistant like Ethereum?

    - Even if an L2 has censorship, as long as users have the ability to withdraw back to L1, then Ethereum's guarantees are preserved. Others argued: It's better if L2s also inherit censorship resistance natively, or else risks remain.

<u>Attack Vectors in Layer 2 Architecture</u>

---

1. Smart Contract Governance (L1 Bridge Contract):

- The L1 smart contract that locks ETH is often administered by the L2 team or foundation.
- This is a single point of failure.
- Risk: if this contract is upgradable or centrally governed, it could be exploited or censored.

2. Sequencer Centralization:

- Sequencers bundle and submit L2 transaction data to L1.
- Many L2s (e.g. Arbitrum, Optimism) use centralized sequencers for performance.
- Risks:
    - Censorship: sequencer may refuse to include a user's transaction.
    - Reordering or front-running.
    - Downtime or malicious submission of data to L1.

3. Data Availability Layer:

- Some L2s post data off-chain to save gas. If this off-chain data is lost or manipulated, users may lose access to prove their balances or exit.

- L2s are developing data availability layers (e.g., Celestia) with new economic security (by issuing tokens, staking, slashing). But these are new trust assumptions. E.g., "We'll punish bad behavior with token slashing." Very few powerful nodes with real computational power might dominate.

- There's a trade-off between performance (scalability) and security: Posting all data on-chain = most secure, least scalable. Off-chain data = scalable, but increases trust and attack surfaces.
- EIP-4844 was brought up: Enables blobs to post L2 data to L1 cheaply (intermediate solution). A step to avoid off-chain storage while maintaining efficiency.
- Off-chain DA layers include systems like Celestia, Avail, and EigenDA. These systems use their own tokens and staking to create economic security. Participants in DA layers stake tokens and get slashed for dishonest behavior (e.g., hiding data). Each L2 ends up creating its own token ecosystem and validator set. This raises questions about added complexity and whether it actually improves decentralization.
- ZK Rollups are **more secure and faster**, but not as scalable today. Optimistic Rollups are **more widely deployed** due to simplicity and EVM compatibility. Many teams are exploring **hybrid approaches** to combine benefits of both.
- The group agreed: All L2s share similar architecture, but differ in their trade-offs across decentralization, speed, and security.

<u>Role of Users & Use Case-Specific L2 Governance</u>

- Users are often unaware or indifferent to the degree of decentralization of each L2. The most popular L2s today are highly centralized but offer low fees and fast transactions. From a user perspective, low cost and speed often outweigh decentralization concerns.
- There is a fundamental governance issue: centralization is incentivized because it's more efficient. This could ultimately harm Ethereum's long-term vision and values if L2s diverge too far. The Ethereum Foundation doesn't directly control L2s and can't enforce governance standards.
- Some participants suggest introducing a threshold or classification system for L2s based on decentralization level. Enterprises may avoid centralized L2s due to security and compliance needs.
- The conversation shifted toward how to educate users and create awareness around L2 risks. There's a need for metrics or dashboards that compare L2s not just on performance but also on decentralization and governance.
    - Participants proposed focusing on L2 attributes to better understand their strengths and ideal use cases. Example: Optimism is aligned with public goods funding due to its governance model and incentives.
    - Each L2 could find a specialized niche in the broader Ethereum ecosystem (e.g., trading, gaming, social, etc.). This niche specialization allows for a more modular and pluralistic Ethereum.

    - There's potential value in researching which L2 architectures are best suited for specific use cases.

- Participants agreed to shift focus of the working group paper from EF's view to user perspective—examining how users assess and choose L2s based on tradeoffs like cost vs. decentralization.

Next Steps

- We will have a reflection meeting. An L2-specific working group session will be scheduled in the coming weeks. IKP working group will rotate its three topics (including L2 governance) biweekly over the next two months.

Cybersecurity Information Sharing Framework

Materials: CS_Cybersecurity Standardshttps://app.mural.co/t/blockchaingovernanceinitiati4922/m/blockchaingovernanceinitiati4922/1738868971396/a1b25de3e4cebf0007984101737f476870ca3633

Presentation by NIST

- NIST (National Institute of Standards and Technology) presented updates on the Cybersecurity Framework (CSF) and community profiles. NIST CSF version 2.0 was released recently (1-year anniversary in February 2024) with significant updates:

    - Addition of a new sixth function: "Govern", which surrounds and supports the original five functions (Identify, Protect, Detect, Respond, Recover).
    - Maintains alignment with international standards (e.g., ISO 27001, COBIT), and introduces online mappings/crosswalks for broader usability.
    - Framework is risk-based and designed for flexibility depending on organization type and needs.
    - Updated resources include quick-start guides tailored for SMEs, ERM integration, and CSF tiers.
    - CSF has been translated into multiple languages, including Japanese, and used internationally (notably in Japan since v1.0).

Community Profiles Overview:

- NIST National Cybersecurity Center of Excellence (NCCoE) facilitates collaborative problem-solving. Community profiles are developed by groups of companies (sectors, subsectors, or shared technology use cases). Different from organizational profiles (individual company targeting current vs. desired cybersecurity posture). Community profiles are templates for groups to manage shared cybersecurity/privacy risks.

- Benefits include:
    - Common taxonomy and shared goals.
    - Alignment with multiple standards.

    - Shared expertise and reduced individual burden.

- Profile structure includes priorities, rationale, informative references, and optionally examples and dependencies.
- NIST has created/posted profiles for threats like ransomware, semiconductors, cyber-physical systems, and more.
- Resources to help communities get started include a draft profile development guide and template.

Feedback and Participation:

- NIST encourages global participation, including non-U.S. entities.
- No formal agreement is required to participate in profile development, but other collaborations (e.g., lab tools) may require a CRADA agreement.

Q&A Highlights:

- On measuring CSF effectiveness:
    - Metrics are a challenge due to CSF's risk-based and flexible structure.
    - Metrics may vary by sector; standardized measurements are difficult but enterprise-focused guides (e.g., NIST SP 8286 series) help integrate with Enterprise Risk Management (ERM).

- Concerns around recent Bybit hack ($1.5B) linked to DPRK threat actors.
    - Emphasized the need for a crypto-specific CSF profile, modeled after the ransomware profile, to address unique risks like key management, blockchain-specific vulnerabilities, etc.
    - Urged NIST and BGIN to collaborate on creating such a profile and enhance real-time threat intelligence sharing, referencing frameworks like STIX/TAXII and CVE/NVD.

- NIST acknowledged the idea and expressed interest in following up, noting:
    - Profiles can evolve into tools/resources later (e.g., for CVEs or automated sharing).
    - It is feasible to extend existing frameworks or create mappings tailored for blockchain and DeFi.

- Participants also discussed the need for domain-specific scoping and realistic timelines for profile development.

<u>Presentation by MITRE</u>

- MITRE is a nonprofit organization that works in the public interest with U.S. government agencies like DHS and DOD. Known for the MITRE ATT&CK framework, which systematically documents adversary tactics and techniques based on real-world attack data. ATT&CK maps adversary behavior from initial access to impact, including reconnaissance, privilege escalation, lateral movement, data collection, exfiltration, and more. ATT&CK is widely used by defenders, SOC teams, red teams, threat hunters, and vendors for threat modeling, detection development, and understanding attacker behavior. MITRE has extended its approach to focus on attacks targeting digital assets, launching a new framework called ADAPT (= Adversarial Actions in Digital Asset Payment Technologies). ADAPT is designed to track and categorize techniques unique to Web3, DeFi, and digital asset ecosystems.

- ADAPT includes many of the same tactics from ATT&CK, such as initial access and execution, but also adds new tactics and techniques specific to crypto:

    - Smart contract logic manipulation
    - Exploitation of gasless (gas-free) RPC endpoints
    - Flash loan exploits
    - DeFi protocol misconfiguration
    - Misrepresentation in off-chain communication (e.g., social engineering or phishing)

    - Layering funds using privacy tools, DEXs, and cross-chain bridges
    - Cross-chain swaps to move funds across blockchains
    - Price oracle manipulation
    - Taking advantage of frontend vulnerabilities

- Unlike ATT&CK, which is strictly based on documented real-world attacks, ADAPT includes both observed and theoretically possible (hypothetical) techniques to anticipate future threats.

- A real case study of a Bybit-related attack was used to demonstrate ADAPT's utility:

    - Attacker crafted a malicious transaction that altered logic in a smart contract wallet.
    - The wallet used a Gnosis Safe multi-sig setup.
    - One of the Bybit executives approved the malicious transaction, likely after being socially engineered.
    - Funds were moved into a contract controlled by the attacker.
    - The attacker obfuscated the trail by using chain-hopping and layering tactics.

- MITRE analysts mapped each step of this attack to specific techniques in ADAPT. The example showed how ADAPT helps break down complex, multi-step attacks in the crypto world. MITRE emphasized the importance of developing a shared understanding

of threats across the crypto ecosystem. ADAPT provides a “common language” to describe and analyze attacker behavior in Web3. MITRE plans to open-source ADAPT and encourages the community to contribute and collaborate.

- The speaker also emphasized that many attacks now span multiple parties (wallets, protocols, exchanges), so shared frameworks like ADAPT help teams across companies understand the full scope of an incident.

- MITRE highlighted the value of information sharing — detection techniques and indicators can be shared in formats like STIX for better collaboration across vendors and defenders.

<u>Discussion on the worksheet</u>

Player Category

- Debate over classifying CERTs and MITRE: MITRE is a nonprofit, FFRDC, and contractor for the US government. Decision: MITRE and similar entities should fall under government entities, not research institutions.

- Suggestion to enumerate pain points and concerns of each category to help clarify roles in the taxonomy.

- A layer-based model (inspired by the CFTC TAC DeFi report) was proposed, with categories like:
    - Protocol layer (e.g., Layer 1 foundations)
    - Network layer (e.g., validators, RPC nodes)
    - Application layer (e.g., DeFi frontends, wallet providers, VASPs, exchanges)

- Recognized the overlap between blockchain developers, suppliers, operators, and suggested refining those categories.

- Suggestion to distinguish between individual open-source developers and corporate developers due to different incentives and information sharing structures.

- Highlighted that developers work across layers, so roles might be repeated.

- Importance of archetypes was emphasized—categories that reflect informational control and response capability.

- Suggestion to keep a high-level breakdown (apps, protocol, network) and then dive deeper into blockchain-specific subcategories.

- Recognized the need for flexibility and future expansion—framework can evolve, starting with a concise, actionable model.

- Security Experts
    - Roles
        - The part of their role will be ingesting information which will inform a variety of different security services, providing threat intelligence or providing security assessments of certain vendors and platforms
        - The role is to leverage threat information to constantly update security assessments and services. For example, the role related to information sharing, related to wallet services would be that a security firm would leverage information shared with them to inform things like their recommendations on using a specific wallet.
    - Incentives
        - The incentive is to get access to the latest threat information so that you can best defend against it. “Access to broader threat intelligence for better security solutions” is the incentive which captured that the DPRK attack information access. They get intel from other groups and practitioners.
    - Challenges
        - At a higher level, it is about reluctance and unwillingness to share information. Is it a challenge by the security expert or instead by the service provider? It is more of a challenge by the service provider, but the security expert also needs to understand this challenge by the service provider.
- Academia
    - Roles
        - Regarding “contribute to standards through sharing of technical expertise and knowledge”, academia is training people to do all stuff so it might be better to change it to “train people through ～”
    - Challenges
        - Access to data / speed and lack of peer review process
    - Conflicts of Interest
        - Limited access to data is not a conflict of interest. But it depends on who’s giving you the data and who’s giving you the funding. Let’s say, if you get data from a blockchain analytics company, you can never say that they do anything wrong. Or if you get money from an exchange, you can never say that they made a mistake, which is a traditional conflict of interest.
- Law Enforcement Authorities
    - Challenges

        - Regarding “Privacy of consumers,” it is really privacy in general because at least 10 years ago in the US, no company wanted to call the FBI because they were worried that the FBI would go see you’ve been doing something else bad and you are now in trouble. There is privacy for consumers and enterprises.

- Financial Regulatory Authorities
    - Challenges
        - We cannot divide cybersecurity risk and financial risk. Sometimes people claim that they were hacked but they are not always really hacked. It might be on purpose.

- Crypto-focused ISAC
    - Challenges
        - They lack the power to enforce. It is not something that can tangibly fixed unless they make it part of the terms of membership of an ISAC
        - If you think of enforcement from regulators, it’s more of a feature to incentivize members sharing information. We also need to take into account that incentive matters but the goal is not to share information but to reduce the attack surface of the industry.
        - If participants say they are not sharing, they are not getting value from the ISAC, which means that the ISAC doesn’t have a reason to exist.

- VASPs
    - Challenges
        - Some VASPs use their own wallet systems, while others use third-party systems. They lack the common schemes of wallet infrastructure between the member VASPs. There is an issue of the absence of mature security assessment methodologies across different types of applications, wallets and others. (This applies to ISACs that are trying to help VASPs better secure themselves. If there is a framework to evaluate open source software and third party vendors, it would be great!)

- Expansion of the common format for cryptocurrency fields that are sticks compatible, then is something that the ISACs need in order to be successful. This can be a point of further action between BGIN and the ISACs. (SEAL is working on defining common formats for storing things such as cryptocurrency addresses and has joined OASIS CTI TC to upstream those changes.)

<u>Next Steps:</u>

- The speaker discusses the importance of turning the discussion into something tangible, operational, and actionable for stakeholders, especially in the context of cybersecurity information sharing.

- Emphasizes that nothing from the discussion will be lost or deleted—everything written down will be used to create a useful document.
- The team plans to compile all the input into a foundational document focused on taxonomy and ecosystem modeling for information sharing in blockchain cybersecurity.
- This initial document will cover roles, responsibilities, and categories of players involved in the ecosystem. It will serve as a “capstone” or starting point for a potential series of documents. The goal is to draft a high-level document that explains the framework, the roles of various entities, and how they interact.
- The speaker asks for volunteers to help draft or “hold the pen” for the document. Many participants express willingness to help; some raise their hands or are acknowledged as key contributors.
- The first draft is targeted for completion around April. The document is expected to be short (5–10 pages), not an extensive technical report.
- If successful, the team might aim to submit it as an ISO standard, which is described as a monumental opportunity for BGIN and the broader blockchain community.

Transition to Post-Quantum Cryptography / Crypto Agility

Materials: BGIN12_Day2_1_B
【Day 2 09:00-10:30 Room B】A Blockchain-based Long-TermTime-Stamping Scheme.mp4

Explores post-quantum cryptography (PQC) and crypto agility for blockchain. Prepare blockchain for quantum threats to asymmetric cryptography (e.g., digital signatures), risking systems like Bitcoin. PQC transition challenges include long timelines (15+ years), compatibility, and need for blockchain-specific plans beyond NIST’s algorithm standards. Discussion about Blockchain-based, long-term timestamping scheme with algorithm renewal to ensure data integrity beyond crypto lifetimes. Debate BEGIN’s role: Define PQC standards, transition mechanisms, or prioritize crypto agility and threat awareness over immediate migration. BEGIN leans toward educating on quantum risks and flexible strategies, avoiding premature PQC mandates.

- Problem Statement on PQC Transition
  - PQC Overview
    - Targets quantum computing risks to asymmetric crypto; symmetric crypto less affected.
  - Quantum break timeline uncertain; past transitions (e.g., 2005) took 15+ years, PQC likely longer.
  - Needs protocols for compatibility, performance, and phased deployment with testing.
  - NIST Efforts
    - Standardizing PQC via competition; selected schemes: CRYSTALS-Dilithium, FALCON, SPHINCS+, FAEST.
  - January 2025 transition document sets deadlines
  - Covers algorithms, not blockchain applications—BGIN could adapt this.

    - Blockchain Risks (2016 Paper)
        - Bitcoin example: Broken SHA-256 enables theft/double-spending; broken ECDSA allows forgery, fake alerts.
    - Impacts layer 2 (e.g., zero-knowledge proofs) if crypto fails.
    - Crypto Agility
        - Ability to switch primitives if compromised; aims for rapid updates without infrastructure overhaul.
    - 2017 idea: Wrap old signatures with secure, long-term schemes (LTB).

- Blockchain-Based Long-Term Timestamping
    - Concept
        - Proposes timestamping to prove data existence over time.
        - Traditional timestamping via TSAs vulnerable to malice or crypto breaks.
    - Blockchain Benefits
        - Decentralized, tamper-resistant, verifiable.
    - Security tied to client-side hash and blockchain crypto (hash/signatures).
    - Long-Term Issue
        - Quantum or lifecycle threats could invalidate timestamps for decades-long data (e.g., government, art).
        - Solution: Renew weak algorithms (e.g., SHA-1 to SHA-2, RSA to FALCON) before full compromise.
    - Scheme Details
        - Formal model prevents tampering, backdating, forging via renewals.
        - Blockchain-side: Group blocks, rehash with stronger functions; transfer assets to new keys.
    - Client-side options: Upload raw data (no privacy), renew hash chain, or link tokens (latest only needed).

- Discussion: Potential BGIN Work Items
    - Proposals
        - Define PQC blockchain requirements (no current standard); create transition plans for non-PQC chains.
    - Scope: Focus on signatures, consider encryption for secrecy (e.g., long-term data).
    - Perspectives
        - Quantum “treasure hunters” could claim unupdated Bitcoin; incentive exists, but logistics tricky.
        - Market may self-correct (e.g., key update services), but quantum risk downplayed (20-30 years off).
        - Client updates are costly; agility over rigid PQC mandates avoids fragmentation.
        - Migration Dynamics
            - Browsers update cheaply; Bitcoin’s decentralized nature makes it harder, costlier.
        - Past migrations (e.g., SHA-1) took 20+ years; Bitcoin’s 20-year signatures heightened urgency.
    - Strategic Options
        - Warning first: Highlight crash risk (e.g., Bitcoin chaos post-quantum break).
        - Agility focus: Flexible designs buy time vs. immediate PQC push.
        - Governance: Hybrid signatures, custody could simplify transitions.

- Next steps:
    - Raise quantum threat awareness, explore agility, delay specific PQC solutions.

Tokenization Initiatives

Materials: BGIN Block#11 MR Tokenization Initiatives.docx【Day 2 11:00-12:30 Room B】Tokenization Businesses by Private Firms - BGIN #12.pdf

Project Agora

1. Initial Discussion and Workstreams of Project Agora

- The session began with a discussion about the structure of Project Agora, emphasizing that different workstreams are handling distinct aspects of the initiative.
- It was explained that:
    - The Technical Workstream focuses on exploring the feasibility of tokenized wholesale central bank money and cross-border payments.
    - The Legal Workstream is responsible for investigating regulatory and legal implications related to tokenized assets and settlements across different jurisdictions.
    - The Communication Workstream manages public-facing information and messaging, ensuring that external communications align with project goals and regulatory sensitivities.

2. Strong Restrictions on Information Dissemination

- The Communication Workstream has prepared an official FAQ document that serves as a reference for any external communications about the project.
- It was emphasized that there are strong restrictions on information dissemination to external members, meaning that discussions and updates must align with the official FAQ.
- The speaker requested understanding from participants that they must be cautious when sharing project details outside of the designated workstreams.

3. Main Objectives of Project Agora

The speaker then introduced the core objectives of Project Agora, explaining that the project was designed to:

- Improve Efficiency in Business and Regulatory Processes in Correspondent Banking

    - Agora aims to enhance cross-border banking operations by reducing transaction times and cutting down transaction costs.
    - The initiative seeks to increase transparency in cross-border transactions, which is particularly relevant for regulatory compliance.

- Address Challenges in Cross-Border Payments
    - The project focuses on making cross-border payments more efficient and transparent by:
        - Streamlining compliance and regulatory reporting for banks.
        - Reducing operational inefficiencies caused by the current fragmented system of correspondent banking.
        - Ensuring compliance with anti-money laundering (AML) and countering the financing of terrorism (CFT) regulations without increasing the burden on financial institutions.
- Enhancing Financial Infrastructure Through Tokenization
    - Project Agora is investigating how tokenization of central bank and commercial bank money can improve settlement processes.
    - The use of a unified regulatory and technical framework is expected to simplify interactions between financial institutions, regulators, and market participants.

4. Future Expansion of the Project

- The project currently involves seven jurisdictions, but there is an expectation that more countries will participate in the future.
- The project is designed to be scalable, meaning that as more financial institutions and regulators join, it should be able to accommodate new jurisdictions and evolving regulatory frameworks.
- It was stressed that early participation and collaboration among banks and regulators are essential for Project Agora's success.

5. Transition to the Next Slide

- After presenting the main objectives, the speaker transitioned to the next part of the presentation, which delves into the technical prototype being developed for wholesale cross-border payments.

6. Introduction to the Technical Prototype

- The session transitioned to discussing how Project Agora is building a technical prototype to test wholesale cross-border payments.
- The primary goal of the prototype is to demonstrate the feasibility of tokenized central bank and commercial bank money in cross-border transactions.
- The speaker outlined that the prototype is designed to address inefficiencies in existing financial systems by using tokenized assets while ensuring regulatory compliance.

7. Key Features and Functionalities of the Prototype

The prototype aims to test and validate four key capabilities:

- Representation of Tokenized Central Bank & Commercial Bank Money
    - The prototype explores how commercial bank deposits and central bank money can be tokenized within a unified regulatory framework.
    - This allows financial institutions to experiment with digital asset settlement without disrupting existing banking relationships.
    - The project investigates the technical and business requirements needed for tokenized payments to function effectively.
- Atomic Cross-Border Transactions
    - One of the core challenges in correspondent banking is the delays in settlement due to multiple intermediaries.
    - The prototype is designed to facilitate atomic settlement, meaning that transactions will either complete in full or not happen at all.
    - The system is structured to preserve the current deposit-bank relationships, ensuring that cross-border payments function similarly to the existing financial ecosystem.
    - The prototype is testing whether transactions can be settled instantly using tokenized assets without increasing financial risks for banks.
- Streamlined Pre-Validation for Payments
    - The prototype incorporates pre-validation mechanisms to reduce the duplication of compliance checks in the payment chain.
    - Today, banks conduct multiple redundant checks at various stages of a transaction to comply with AML/CFT regulations.
    - Project Agora aims to standardize and automate pre-validation to reduce processing times and operational costs.
    - The objective is to improve the efficiency of regulatory compliance without changing existing legal standards.
- Compliance with AML, CFT, and Sanctions Screening
    - The current cross-border payment system has compliance bottlenecks, particularly in sanctions screening and anti-money laundering (AML) rules.
    - The prototype explores whether a unified system can improve compliance efficiency without compromising security.
    - One challenge is ensuring that the tokenized payment system adheres to existing international standards for AML, KYC (Know Your Customer), and counter-terrorism financing rules.
    - The project also evaluates how real-time compliance checks can be built into the settlement system.

8. Legal and Regulatory Issues Identified

- The discussion then shifted to the legal and regulatory challenges that arise from tokenized cross-border transactions.
- The project is analyzing potential legal gaps across multiple jurisdictions and how they may impact settlement finality.
- One major challenge is that different countries have different definitions of “tokenized central bank money” and “commercial bank deposits.”
- The team is working on solutions to ensure legal consistency across borders while allowing each jurisdiction to maintain its monetary sovereignty.

9. Importance of Interoperability in Cross-Border Payments

- The speaker emphasized that for tokenized payments to be widely adopted, they must be interoperable across different financial systems.
- The goal is to ensure that tokenized central bank money and commercial bank deposits can function seamlessly across various jurisdictions.
- The project is exploring how to integrate existing financial infrastructures (such as SWIFT and domestic RTGS systems) with a new tokenized settlement network.

10. Three Key Principles for a Common International Payment Platform

The speaker elaborated on three fundamental principles that any common international cross-border payment platform should adhere to:

(i) Open, Transparent, and Secure System with Monetary Sovereignty Considerations

- A cross-border payments platform must be open and transparent to gain broad adoption by central banks and commercial financial institutions.
- Security must be prioritized to ensure trust and resilience in the financial system.
- Monetary sovereignty must be preserved, meaning that:
    - Each participating country should have control over its own currency within the system.
    - Central banks should be able to manage and regulate transactions involving their national currencies.
- The project must accommodate diverse monetary policies while maintaining a common technical framework.

(ii) Avoidance of Fragmentation in Financial Markets

- A major concern raised in the BOJ report was that introducing a new international platform could fragment financial markets if not designed properly.
- Price formation and market liquidity in foreign exchange (FX) and interbank markets must remain intact.

- Post-trade processing on the new platform should not disrupt existing FX market structures.
- It was stressed that if the new system unintentionally increases liquidity needs or settlement delays, it could discourage financial institutions from participating.
- The platform must seamlessly integrate with trading platforms and existing settlement systems to avoid harming market liquidity.

(iii) Standardized Data Formats and Messaging Protocols

- Data standardization is essential to ensure smooth integration with existing trading, settlement, and compliance systems.
- The new system must align with current global standards, such as ISO 20022, to ensure compatibility with banks' existing infrastructures.
- A major issue in today's correspondent banking system is inconsistent messaging protocols, which cause delays and inefficiencies.
- Harmonization of messaging protocols would allow for:
    - Faster pre-validation and reconciliation of transactions.
    - Easier adoption by financial institutions without costly infrastructure overhauls.
    - Improved compliance screening through automated data-sharing mechanisms.

12. Addressing Settlement & Liquidity Challenges

- The speaker then introduced another critical issue in cross-border payments:
    - The increased liquidity demands that may arise from a tokenized settlement system.
    - If the system substantially increases the need for intraday liquidity, it could be counterproductive and deter adoption.
- Many FX transactions today are settled with minimal liquidity requirements, thanks to netting effects from clearing houses like CLS Bank.
- If a new tokenized system significantly increases liquidity requirements, banks may be reluctant to use it.
- To address this concern, Project Agora is exploring functionalities to optimize liquidity management, including:
    - Netting mechanisms to reduce the volume of real-time transactions requiring settlement.
    - Intraday liquidity funding facilities to ensure banks can meet liquidity demands efficiently.

13. Designing for Scalability and Future Adoption

- The speaker reiterated that the platform is being designed to scale, allowing more central banks and financial institutions to participate over time.

- The system should be flexible enough to integrate new innovations while maintaining compatibility with existing financial infrastructure.
- It was noted that Project Agora expects more jurisdictions to join beyond the initial seven currently involved.

Global Layer 1

14. Transition to GL1 Discussion

- Following the roundtable introductions, the discussion moved to Global Layer 1 (GL1), an initiative focused on building a digital infrastructure to support tokenized financial instruments.
- The speaker introduced GL1 as a multi-purpose shared ledger infrastructure that aims to be:
    - Regulatory-compliant and developed with input from regulated financial institutions.
    - Interoperable across various digital asset networks to ensure seamless integration with existing financial markets.
    - Scalable to support high transaction volumes and evolving financial instruments.

15. Overview of the Challenges GL1 Seeks to Solve

- The speaker highlighted that existing digital asset ecosystems suffer from several critical issues, including:

    (i) Lack of Interoperability

    - Digital assets today exist on multiple, fragmented networks, leading to inefficiencies.
    - Banks and financial institutions struggle to interact with decentralized finance (DeFi) systems because of differing standards and technological frameworks.
    - GL1 aims to bridge the gap between traditional finance (TradFi) and decentralized finance (DeFi) by establishing a common infrastructure.

    (ii) Fragmented Asset Pools

    - Financial institutions currently operate within walled gardens, meaning that tokenized assets are restricted within specific networks.
    - This results in lower liquidity and inefficiencies when settling transactions across different financial ecosystems.
    - GL1 proposes a unified platform where tokenized assets can interact across multiple institutions and regulatory environments.

    (iii) Differing Regulatory & Compliance Standards

- Financial institutions must navigate complex compliance requirements across jurisdictions.
- A lack of common standards for tokenized assets makes cross-border settlement more complicated.
- GL1 intends to align with global financial policies to ensure smoother regulatory adoption.

(iv) Privacy & Security Concerns

- Digital asset networks vary in their levels of privacy protections.
- Institutional players require strong identity verification and transaction traceability for AML/CFT compliance.
- GL1 will integrate privacy-preserving technologies while ensuring compliance with financial regulations.

(v) Scalability Issues in Digital Asset Networks

- Existing public blockchains struggle with transaction speeds and costs.
- Many institutional players hesitate to adopt blockchain-based settlements due to concerns about network congestion and high fees.
- GL1 is designed to be highly scalable, ensuring that large-scale financial transactions can be processed efficiently.

16. The Three Proposed Models for GL1

The speaker outlined three possible models for how GL1 could function in practice:

Model 1: Public Permissionless

- This model is similar to Ethereum or other public blockchains, where anyone can participate.
- Advantages:
  - Open access to a wide range of participants.
  - High level of decentralization.
- Disadvantages:
  - Regulatory concerns over AML/CFT compliance.
  - Risk of illicit activity, making it unattractive for institutional adoption.

Model 2: Private Permissioned

- A closed network operated by a consortium of financial institutions.
- Advantages:
  - Stronger control over regulatory compliance.
  - More predictable governance and security.
- Disadvantages:

    - Limited interoperability with external financial networks.
    - Potential centralization risks, reducing its attractiveness to decentralized finance (DeFi) participants.

Model 3: Public Permissioned (Hybrid Model)

- A hybrid model combining openness with controlled access.
- Features:
    - Open to participation, but permissions are granted based on regulatory compliance.
    - Different levels of access for different participants (e.g., banks, regulators, fintech firms).
    - Validators ensure compliance while maintaining decentralization principles.
- This model is considered the most promising approach, as it balances regulatory requirements with innovation.

17. How GL1 Fits into the Broader Financial Landscape

- The speaker emphasized that GL1 is positioned as a foundational infrastructure layer, rather than a competing financial product.
- Unlike standalone tokenized assets (e.g., stablecoins or tokenized securities), GL1 aims to be an underlying settlement layer that supports various financial activities, including:
    - Central bank digital currencies (CBDCs).
    - Tokenized commercial bank deposits.
    - Stablecoins issued by regulated financial institutions.
    - Programmable financial instruments such as automated market makers (AMMs).
- The project is being developed with the vision that institutions will build applications on top of GL1, rather than replacing existing financial structures.

18. Challenges in Tokenization, Interoperability, and Institutional Adoption of Digital Asset Infrastructure

- The discussion shifted from explaining Global Layer 1 (GL1) to analyzing the key challenges faced by tokenization initiatives and financial institutions considering adoption.
- The speaker emphasized that technology alone is not enough—there are significant regulatory, operational, and market-related challenges that must be addressed.
- The conversation focused on the real-world obstacles to implementing tokenized financial infrastructure, particularly in the context of cross-border payments and institutional adoption.

19. Key Challenges in Institutional Adoption of Tokenized Systems

The discussion outlined several challenges that financial institutions, regulators, and technologists face when transitioning to tokenized assets.

(i) Lack of Standardization Across Tokenized Financial Networks

- The financial sector is highly fragmented, with various banks, central banks, and fintech companies developing different tokenization solutions.
- There is no universal standard for:
    - Tokenized financial instruments (e.g., tokenized deposits, stablecoins, wholesale CBDCs).
    - Interoperability protocols between private blockchains and traditional financial networks.
    - Compliance frameworks for cross-border tokenized settlements.
- Without standardization, institutions hesitate to adopt tokenization due to the risk of incompatibility with existing systems.

(ii) Challenges in Interoperability Between Traditional Finance (TradFi) and Tokenized Finance

- One major issue is the difficulty of integrating tokenized assets into legacy banking infrastructure.
- Existing payment networks (SWIFT, RTGS systems, interbank settlement platforms) were not built to handle blockchain-based digital assets.
- Regulators and financial institutions worry about how to facilitate smooth transitions from traditional finance to tokenized systems without disrupting financial stability.
- Financial institutions are concerned that operating on fragmented tokenized networks could increase complexity rather than simplify payments.

(iii) Privacy & Compliance Risks in Tokenized Financial Transactions

- Tokenization raises significant compliance challenges, particularly in:
    - AML/CFT (Anti-Money Laundering & Counter-Terrorism Financing) regulations.
    - Sanctions screening (ensuring restricted entities do not participate).
    - KYC (Know Your Customer) standards across jurisdictions.
- A key question is how compliance will be enforced in tokenized environments:
    - Will real-time compliance checks be possible?
    - Will banks need to update their AML screening tools to accommodate tokenized transactions?
    - How will financial crime monitoring adapt to new payment models enabled by tokenization?

(iv) Balancing Institutional Control vs. Decentralization

- Traditional financial institutions prefer controlled environments, where:
    - Transaction monitoring and compliance enforcement are centralized.
    - Liquidity risks are mitigated through existing oversight mechanisms.
- In contrast, crypto-native ecosystems favor decentralized approaches, where:
    - Transactions occur peer-to-peer with minimal institutional oversight.
    - Regulatory enforcement happens at the smart contract level, not through centralized intermediaries.
- Bridging these two approaches is a major challenge, as financial institutions seek regulated tokenization frameworks while maintaining control over risk management.

(v) Market Incentives for Financial Institutions to Participate

- Many banks are hesitant to engage with tokenized systems unless there are clear commercial benefits.
- Financial institutions require strong incentives to invest in:
    - New compliance infrastructure for tokenized finance.
    - Liquidity provisioning for digital asset settlement.
    - Operational restructuring to integrate tokenized deposits or CBDCs.
- Without a clear business case, banks and financial institutions may resist adoption despite the potential technological benefits.

20. Discussion on Institutional Hesitation Toward Tokenization

- A financial institution representative expressed concerns about the current fragmentation in tokenization efforts.
- They noted that many financial institutions are waiting for regulatory clarity before making major investments in digital assets.
- The lack of consistent definitions for tokenized deposits and stablecoins across jurisdictions is creating uncertainty.
- Another participant from a regulatory body stated that regulators are moving cautiously:
    - They recognize the potential of tokenization to improve efficiency, but they also see risks that need to be mitigated first.
    - Regulators are particularly concerned about shadow banking risks, where non-bank entities issue tokenized financial instruments without proper oversight.

    - The lack of transparency in some DeFi-based tokenization initiatives is a red flag for regulators.

21. The Role of Private Sector Tokenization Efforts

- The conversation shifted to discussing how private sector initiatives, such as stablecoins and tokenized deposits, are competing with institutional tokenization projects like Project Agora and GL1.

- A speaker highlighted that several large financial institutions are already issuing tokenized assets outside of regulated frameworks.

- Examples discussed:

    - JPMorgan's Onyx and tokenized deposits.
    - BlackRock and other asset managers launching tokenized real-world assets.
    - DeFi platforms experimenting with tokenized US Treasuries and other financial instruments.

- Key question raised:

    - Will institutions prefer private-sector-led tokenization solutions over public-sector-driven projects like Project Agora?
    - Will large banks create their own tokenization networks instead of adopting industry-wide infrastructures like GL1?

22. Transition to the Debate: Public vs. Private Tokenization Initiatives

- After discussing the challenges and potential solutions for institutional adoption of tokenized finance, the conversation shifted toward the competition between public and private tokenization initiatives.

- Participants explored whether financial institutions will adopt government-backed tokenization frameworks (like Project Agora and GL1) or prefer private sector-led models (such as JPMorgan Onyx, BlackRock, and Citibank's tokenization efforts).

- The key questions driving this discussion:

    - Will private banks and asset managers dominate tokenized finance, leaving government-led initiatives behind?
    - Can public and private initiatives collaborate, or will their competing interests lead to further market fragmentation?
    - How will regulatory oversight evolve in a landscape where private institutions tokenize assets independently?

23. Understanding the Private Sector's Tokenization Efforts

A speaker outlined the major private-sector players currently leading tokenization efforts:

- JPMorgan Onyx:
    - JPMorgan has developed a private permissioned blockchain (Onyx) for institutional-grade tokenized deposits and payments.
    - Onyx is heavily integrated into JPMorgan's own banking system, making it a walled garden rather than an open financial network.
    - The JPM Coin, a tokenized deposit, is already being used for internal settlement between JPMorgan's clients.
- BlackRock's Tokenization Strategy:
    - BlackRock has begun issuing tokenized money market funds and real-world assets (RWAs).
    - Their approach focuses on tokenized treasuries and private credit markets, giving institutional investors more efficient ways to trade fixed-income securities.
    - BlackRock's strategy is heavily reliant on institutional investment demand rather than broader financial system transformation.
- Citi's Tokenized Deposits:
    - Citi is working on a hybrid model that combines tokenized deposits with regulated financial infrastructure.
    - Their goal is to facilitate programmable payments while ensuring compliance with global banking regulations.
- Private Stablecoin Issuers (USDC, USDT, etc.):
    - USDC (issued by Circle) and USDT (Tether) dominate the tokenized dollar space.
    - These privately issued digital dollars are already used in cross-border trade, DeFi, and remittances, competing with potential public-sector tokenized settlement solutions.

Key takeaway from this segment:

- Private sector firms are moving fast to tokenize financial assets.
- Their goal is to create institutionally focused solutions that align with their existing business models and customer base.
- Unlike public-sector projects (GL1, Agora), private firms do not have a mandate to create an inclusive financial system—their priority is profit and efficiency.

24. Arguments in Favor of Public-Sector Tokenization Initiatives

Several participants defended the role of public-sector tokenization efforts, arguing that government-backed initiatives offer unique benefits:

(i) Ensuring Market Stability & Financial Integrity

- Central banks and regulators play a key role in maintaining financial stability.
- If tokenization becomes too privatized, there is a risk of shadow banking and regulatory arbitrage.
- Public initiatives like GL1 and Agora ensure that tokenized assets operate within existing financial stability frameworks.

(ii) Avoiding Market Fragmentation

- If every bank or institution builds its own proprietary tokenized system, the result will be financial silos that do not interact.
- This would replicate the inefficiencies of today's correspondent banking system rather than solving them.
- Publicly managed, open-access tokenization infrastructures (like GL1) can serve as a unifying layer, ensuring interoperability across different tokenized ecosystems.

(iii) Supporting Financial Inclusion

- Many private tokenization efforts focus only on high-net-worth investors and institutional clients.
- Public-sector initiatives have a broader mandate to ensure that tokenized finance benefits all segments of the economy, not just the wealthiest players.

(iv) Aligning Tokenization with Monetary Policy Goals

- If large-scale tokenized deposits and stablecoins become dominant, they could erode the role of central bank money.
- A government-backed tokenized payment system would ensure that monetary policy transmission remains effective.
- Without central bank oversight, tokenized finance could undermine traditional banking stability.

25. Counterarguments in Favor of Private-Sector-Led Tokenization

Others in the discussion argued that private-sector initiatives are moving faster and are more capable of driving innovation.

(i) Public-Sector Innovation is Slow & Bureaucratic

- Government-led financial innovation is often slow-moving, with multiple layers of approvals and risk aversion.

- Private banks and fintech firms have more agility, allowing them to experiment, iterate, and improve tokenized finance solutions at a faster pace.

(ii) Private Companies Have Stronger Commercial Incentives

- Financial institutions will not adopt a system just because it is government-backed—they need clear revenue opportunities.
- Private tokenization efforts are built with profitability in mind, making them more appealing to banks.
- JPM Coin and tokenized BlackRock funds already have real-world adoption, whereas GL1 and Agora are still in exploratory stages.

(iii) Private Initiatives Offer Better User Experience

- Private firms prioritize efficient user interfaces, low transaction costs, and institutional-grade security.
- Government-backed infrastructures often lag in usability and technological sophistication.
- If public-sector initiatives fail to offer a superior experience, banks and investors will naturally gravitate toward private solutions.

26. Potential Collaboration Between Public and Private Tokenization Efforts

- Rather than choosing between public vs. private tokenization models, some participants suggested that the best path forward is collaboration.

- Possible models for public-private collaboration:

    - Regulated financial institutions could use GL1 or Agora as a base layer, while developing their own tokenized products on top.
    - Central banks could set tokenization standards while allowing private firms to build competitive solutions within those frameworks.
    - Private tokenized financial instruments (like JPM Coin or tokenized US Treasuries) could be made interoperable with central bank-regulated tokenized deposits.

- A participant from a regulatory body noted that while public tokenization projects offer stability, they need the private sector's expertise in innovation and market deployment.

- A financial institution representative stated that a hybrid approach, where public and private models coexist under a shared compliance framework, could be the most practical solution.

27. Transition to Stablecoin Discussion

- After debating the public vs. private tokenization models, the conversation shifted to the role of stablecoins in the evolving tokenized financial system.
- Participants explored key questions:
    - Are stablecoins complementary to tokenized bank deposits, or do they pose a competitive threat?
    - Can stablecoins improve cross-border payments more efficiently than government-backed tokenized systems like Project Agora?
    - How should stablecoins be regulated, and what risks do they introduce to the broader financial system?

28. Overview of Stablecoin Adoption and Market Trends

A participant provided a market overview of stablecoins, highlighting their growth, use cases, and evolving regulatory landscape.

- Current stablecoin market size:

    - As of early 2025, the total stablecoin market capitalization is approximately $220 billion, with USDT (Tether) and USDC (Circle) dominating the sector.
    - Significant growth in tokenized real-world assets (RWAs) has driven demand for stablecoins as a settlement layer.
- Primary use cases of stablecoins:

    - Cross-border remittances:
        - Stablecoins offer faster and cheaper international payments compared to traditional correspondent banking systems.
    - DeFi and financial markets:
        - Many crypto-native applications use stablecoins as the primary form of collateral and trading pair.
    - Institutional adoption:
        - Companies like Visa and PayPal have begun integrating stablecoins into payment systems.
    - Tokenized asset settlement:
        - New initiatives, such as tokenized US Treasuries and securities, use stablecoins for instant settlement.
- Growing institutional interest:

    - Major financial institutions, including JPMorgan and BlackRock, are exploring stablecoins for internal settlements.
    - Regulated financial institutions are starting to issue their own stablecoins, challenging the dominance of crypto-native stablecoin issuers.

29. Are Stablecoins a Complement or a Competitor to Tokenized Bank Deposits?

The debate then shifted to whether stablecoins should be viewed as a complement to traditional finance or as a disruptive competitor.

(i) Argument: Stablecoins are a Complement to Tokenized Bank Deposits

- Stablecoins can enhance cross-border transactions and settlement speed for institutions that still rely on slow, costly banking systems.
- They offer liquidity and accessibility that traditional finance lacks, particularly for individuals and businesses in emerging markets.
- Financial institutions could leverage stablecoins within tokenized financial ecosystems rather than seeing them as competition.
- If properly regulated, stablecoins could serve as an on-ramp to tokenized finance, helping financial institutions transition toward digital asset adoption.

(ii) Argument: Stablecoins Compete with Tokenized Bank Deposits & Pose Risks

- Stablecoins challenge traditional bank deposits by offering a more efficient, borderless alternative.
- Privately issued stablecoins could reduce reliance on central bank money, potentially impacting monetary policy.
- Many stablecoins operate outside regulatory frameworks, leading to concerns about financial stability, illicit activity, and counterparty risk.
- If stablecoins become dominant in cross-border transactions, banks could lose control over international settlement networks.

Key question raised:

- Will banks integrate stablecoins into regulated tokenized financial networks, or will they push for stricter regulations to limit their influence?

30. Regulatory Challenges and Risks of Stablecoin Adoption

A regulatory expert outlined the major concerns financial authorities have regarding stablecoins:

(i) Lack of Clear Regulatory Oversight

- Stablecoin issuers operate under different regulatory frameworks depending on jurisdiction.
    - Some jurisdictions treat stablecoins as payment instruments, while others classify them as securities.
- Financial regulators are struggling to create a uniform framework for stablecoin governance.

(ii) Reserve Backing and Redemption Risks

- Not all stablecoins are fully backed by safe assets.
    - USDC and USDT claim to be fully backed by cash and short-term US Treasuries, but concerns about audit transparency remain.
    - Algorithmic stablecoins (such as Terra/Luna, which collapsed in 2022) have historically posed systemic risks.
- Questions raised:
    - How can regulators ensure stablecoin reserves are properly backed and audited?
    - Should stablecoin issuers be subject to banking regulations similar to traditional financial institutions?

(iii) Systemic Risks and Financial Stability Concerns

- Widespread adoption of stablecoins could introduce new risks to the global financial system.
    - If a major stablecoin issuer collapses, it could trigger liquidity crises across financial markets.
    - Stablecoins compete with commercial bank deposits, potentially reducing the effectiveness of monetary policy.
    - Unregulated stablecoin adoption in emerging markets could weaken local financial institutions.
- Regulators are discussing whether to enforce:
    - Capital requirements for stablecoin issuers to ensure financial stability.
    - Restrictions on stablecoin reserves, requiring them to hold only cash and government securities.
    - Stricter AML/CFT compliance to prevent illicit transactions.

31. Stablecoins vs. Central Bank Digital Currencies (CBDCs)

The conversation then turned to whether CBDCs could replace stablecoins or if the two would coexist.

- A central bank representative argued:
    - CBDCs could eliminate the need for privately issued stablecoins by providing a government-backed digital currency with the same benefits.
    - A well-designed CBDC would offer financial stability without the risks associated with private stablecoin issuers.
    - Central banks should not allow stablecoins to become systemically important before regulatory frameworks are in place.

- A counterargument from a fintech expert:
    - Stablecoins already serve market demand for digital dollars—governments may be too slow to launch CBDCs before stablecoins become dominant.
    - CBDCs are unlikely to completely replace stablecoins, especially in DeFi and crypto-native markets where private stablecoins have already established liquidity.
    - Regulated financial institutions may integrate stablecoins alongside CBDCs, rather than viewing them as direct competitors.

32. Future of Stablecoin Regulation: What Comes Next?

- The conversation closed with predictions on how stablecoin regulation will evolve.
- A regulatory expert predicted:
    - Tighter stablecoin regulation is inevitable, particularly for issuers handling large transaction volumes.
    - Expect global coordination efforts, possibly through G20, BIS, or IMF frameworks.
    - Banks and financial institutions may start issuing their own stablecoins, leading to a shift toward fully regulated tokenized deposits.
- A financial institution representative speculated:
    - Stablecoins will continue to grow, but regulators will push issuers toward stricter compliance.
    - Financial institutions will likely integrate stablecoins into regulated banking systems rather than banning them outright.
    - Projects like Agora and GL1 could provide a compliant alternative, attracting financial institutions away from unregulated stablecoins.

33. Transition to the Final Discussion: The Future of Tokenized Finance

- The moderator summarized the key takeaways:
    - Stablecoins are playing an increasingly significant role in tokenized finance.
    - There is an ongoing debate on whether stablecoins complement or compete with tokenized bank deposits.
    - Stablecoins pose regulatory challenges, including reserve backing, financial stability risks, and AML/CFT compliance.
    - CBDCs may serve as an alternative, but stablecoins already dominate key financial use cases.
- The final segment of the discussion would explore the future of tokenized finance, including:

- How will financial markets evolve in response to tokenization?
- What role will central banks, regulators, and private institutions play?
- What are the key next steps for projects like Agora and GL1?

Stablecoin Challenges

Materials: Bruno - Stablecoin Regulations.mp4
Stablecoin regulation comparison v1.docx

Presentation by Chloe: Stablecoin Regulations

- The paper is a continuation of BGIN's years-long research on stablecoin risks and failures. Focus of the paper has shifted to comparing regulatory responses to stablecoin risks, especially after the events of 2022.
- Emphasized the importance of historical context, as regulatory frameworks are often shaped by crises. Stablecoin evolution is divided into three phases in the paper.
    - In the early era (pre-2019), regulators were largely inactive; main concerns were AML/CFT, tax, and property issues. Key stablecoins like Tether, USDC, and DAI emerged during this period.
    - In 2019, Facebook's Libra project marked a turning point by drawing intense scrutiny from global policymakers. Libra triggered widespread regulatory fear due to Facebook's existing reputational issues.
    - The COVID-19 pandemic led to increased demand for stablecoins, driven by market volatility and digital asset adoption. Major collapses in 2022, such as Terra/Luna and Celsius, brought stablecoin risk to the forefront of policy discussions. Terra's collapse was especially influential in driving a global regulatory response.
    - One of the main concerns post-2022 was the difference between algorithmic and fully-backed stablecoins. Other concerns included rehypothecation, lack of audits, and poor reserve management.
- VARA and MiCA are the two regulatory regimes closely examined in the paper.
    - Both prohibit rehypothecation of reserve assets.
    - Both regimes prohibit paying interest or offering yield to holders of stablecoins.
    - Both require stablecoin issuers to undergo third-party audits.
    - Issuers in both regimes must publish a white paper subject to approval.
    - Both demand segregation of customer assets from company assets.
    - Custody requirements mandate full backing with highly liquid, low-risk assets.
    - Redemption processes must be quick and seamless.

    - Prudential rules limit the type of collateral that can be used (favoring cash-like instruments).

- Note that there is now an emerging conversation questioning whether the prohibition of interest is too conservative. Abu Dhabi is cited as an example of a jurisdiction reassessing the prohibition of interest and exploring more flexible frameworks.

- Circle received the first MiCA license for stablecoin issuance, a significant development under the new EU rules.

- Stressed that current regulations are reactive, shaped by past failures rather than forward-looking design. She noted the opportunity for BGIN to bring in more multi-stakeholder perspectives on under-discussed topics like prudential regulation.

- Suggested adding more recent events, such as US political momentum on crypto, into the paper's next revision. The section on future policy considerations is intentionally left open for input from the working group.

<u>Discussion</u>

- One participant asked several key questions around regulatory classification, global vs. non-global stablecoin standards, capital requirements for banks issuing stablecoins, and regulatory extraterritoriality.

  Regulatory Classification of Stablecoins

    - Emphasized that after the Terra-Luna collapse, algorithmic stablecoins became politically and reputationally toxic. Regulators reacted by banning or avoiding them entirely rather than managing their risks more thoughtfully.

    - There was a call to consider more nuanced classification frameworks that distinguish between stablecoins and deposit tokens, and even within stablecoins (e.g., fiat-backed vs. crypto-collateralized vs. algorithmic). This point remained open-ended, with agreement that it's an area ripe for further research and clarification.

  Global vs. Non-Global Stablecoins (FSB Distinction)

    - Noted that supervision of global stablecoins is a current gap — especially how to regulate foreign stablecoins used within a jurisdiction.

    - Acknowledged that many regimes (like the EU's MiCA) still lack strong extraterritorial mechanisms for supervising stablecoins issued elsewhere. While the FSB classification wasn't deeply analyzed, the broader theme of cross-border supervisory challenges was discussed.

Capital Requirements for Bank-Issued Stablecoins

- Both MiCA and Dubai's VARA require high-quality, liquid reserve assets. There are prudential requirements such as asset segregation and liquidity for redemption, but these are not as developed or stringent as Basel-style capital requirements for banks.

- The conversation acknowledged that stablecoin issuers may be treated differently from banks, even when offering similar financial services — and that this could be a regulatory inconsistency.

- It was implied that more consistency may be needed, especially if banks get involved in issuing stablecoins.

Regulatory Extraterritoriality

- Noted that regimes like MiCA include restrictions on offering unlicensed stablecoins in the EU, but enforcement mechanisms and coordination with foreign jurisdictions remain unclear.

- Emphasized the importance of tracking how different jurisdictions allow or restrict trading of foreign-issued stablecoins (e.g., Singapore allows USDT trading; the EU may restrict it).

- There was no concrete solution discussed, but a clear recognition of the fragmentation and enforcement difficulties in cross-border regulation.

- Raised the question of whether stablecoins should be regulated as harshly as deposit tokens, given their different risk profiles. Suggested the need for a more nuanced regulatory framework that considers the specific risks of each type of product, rather than applying blanket restrictions or bans.

<u>Discussion: contradictions and inconsistencies in current regulations</u>

- Questioned why algorithmic design (which promotes automation and transparency) is penalized, despite potential for better rule compliance.

    - Pointed out that Circle's USDC, widely seen as compliant, does not offer universal redemption rights, as only authorized partners can redeem.

    - Argued that such distinctions (between financial instruments and stablecoins) are vague and poorly defined in MiCA.

    - Raised concerns about regulations requiring full redemption while simultaneously permitting issuers to invest reserve assets (limiting liquidity).

- Questioned whether stablecoins are being unfairly limited from being means of payment, despite being inherently suited for that function.
- Asked whether algorithmic stablecoins created entirely by smart contracts are considered to have an issuer under existing legal definitions.
    - Emphasized that smart contracts could potentially offer greater trust and compliance than human issuers, but regulations still favor legal entities.
    - There was a question of how accountability would be handled in the absence of a central issuer, answered by likening this issue to self-driving cars and AI, where regulatory frameworks still struggle to assign responsibility.
    - MiCA requires issuers to monitor non-euro stablecoin usage and potentially cap its use as a payment method, especially in Europe.Concerns were raised that this may centralize risk (e.g., with USDC) and disadvantage decentralized or alternative stablecoins.
- Clarified that algorithmic stablecoins can charge small mint/burn fees as a security measure, and that fees are not necessarily profit-driven.
    - Added that fees are critical to mitigate risks like Oracle manipulation and front-running attacks in crypto-backed stablecoins.
    - A question was raised about how stablecoin issuers make money; Clarified that it's primarily via investment of reserves or small operational fees. Argued that by prohibiting fees, regulators force issuers to invest reserves, introducing more risk.
- Acknowledged that prudential and cyber risks (e.g., Oracle manipulation, smart contract hacks) are underexplored in current regulation. Note that while stablecoins are easier to trace due to blockchain transparency, regulations lack clarity on issuers' obligations once suspicious activity is detected.
- A unique value of BGIN was emphasized: it can facilitate direct Q&A-style discussions between algorithmic stablecoin developers and regulators. Participants agreed on the value of publishing a document presenting questions with regulatory responses as a form of multi-stakeholder dialogue.

<u>Discussion: illicit activities with the use of stablecoins</u>

- Deloitte Japan presented its JFSA research on the use of stablecoins in illicit activities.
    - Outlined the broader stablecoin ecosystem value chain, identifying key actors: issuers, exchanges, payment service providers, wallets, merchants, and dApps.
    - Emphasized that most AML/CFT efforts focus only on issuers and exchanges, but emerging risks also lie with payment processors and merchants.

    - The ecosystem lacks sufficient solutions for stablecoin AML compliance in merchant and point-of-sale contexts.

- Confirmed a growing use of stablecoins in laundering due to their liquidity and availability, unlike Monero or other privacy coins.

- There is a tension between the ability of stablecoin issuers to freeze funds and the lack of regulatory clarity on when they are expected to act. Stablecoin issuers are technically capable of freezing tokens via smart contracts, but risk reputational and business consequences. There is a need for defined categories of "clear-cut" illicit behavior to guide timely freezes or reporting actions, highlighting the lack of clear global frameworks for freezing assets or enforcing blacklists, given divergent national sanctions lists.

- Embedded supervision was mentioned as a novel regulatory approach but requires clarity on who holds ultimate decision-making power (e.g., regulators vs. private actors).

- The group reiterated that further research and regulatory discussion should be held, particularly on AML challenges tied to stablecoins used in commerce. Stablecoin risk mitigation should evolve beyond just technical monitoring to include governance clarity and broader industry dialogue.

Wallet Governance

Materials: BGIN_WD_SR00**_ Wallet Governance and Policy Study Report
IKP_Accountable Wallet Accountable Wallet - BGIN #12.pptx.pdf

1. Background and Motivation for the Accountable Wallet

- Addressing the Problem Space

    - The speaker begins by setting the context for the problem the Accountable Wallet aims to address.
    - They cite recent high-profile incidents in the crypto space, particularly exchange hacks and DeFi exploits that have resulted in significant financial losses.

- Types of Security Threats Identified

    - The speaker categorizes three major security concerns affecting decentralized transactions:
        - Exchange and platform vulnerabilities – Billions in losses due to exchange breaches.
        - DeFi attack vectors – Manipulation through flash loan exploits, sandwich attacks, and smart contract loopholes.
        - Illicit finance risks – Despite existing monitoring tools, money laundering remains a challenge.

- The Growing Complexity of Transaction Tracking
    - The speaker highlights that Layer 2 solutions, rollups, and privacy-enhancing technologies are making transaction tracking increasingly complex.
    - They explain that as scaling solutions improve, transaction data is becoming more difficult to analyze, leading to concerns about compliance and transparency.

2. Philosophy Behind the Accountable Wallet

- Acknowledging that a perfect solution does not exist, the speaker sets realistic expectations:
    - "We recognize that there is no single mechanism capable of completely eliminating illicit activity in decentralized transactions."
    - Instead of attempting to block every illicit transaction, the goal is to help legitimate users protect themselves from inadvertently engaging with illicit funds.
- Proposed Approach: A Practical Framework for Trust
    - The Accountable Wallet is framed as a proactive solution that helps users:
        - Prove their legitimacy before engaging in transactions.
        - Avoid exposure to illicit funds by filtering out interactions with suspicious sources.
        - Preserve privacy while still complying with legal and financial regulations.
    - The analogy of "building protective barriers" is used to describe how the system helps ensure compliance for honest actors rather than focusing on eliminating bad actors directly.

3. Discussion on Current Security Threats

The speaker outlines three main categories of illicit activities in decentralized finance:

(a) Security Breaches and Hacks on Crypto Platforms

- Large-scale exchange hacks have resulted in billions of dollars in losses over the past decade.
- Despite improvements in security infrastructure, audits, and operational safeguards, hackers continue to exploit vulnerabilities in both centralized and decentralized platforms.
- The speaker mentions notable DeFi exploits, stating that:
    - Some attackers directly exploit vulnerabilities in smart contract code.
    - Others use advanced financial strategies such as flash loan attacks to manipulate market prices and extract profits without technically breaking any rules.

(b) Money Laundering via Decentralized Networks

- The speaker highlights that illicit transactions are increasingly difficult to track as decentralized financial tools evolve.
- Privacy-enhancing technologies and Layer 2 solutions allow users to conduct transactions off-chain, making traditional forensic tracking methods less effective.
- The growing adoption of cross-chain asset transfers makes it even harder to trace the origins of funds, enabling bad actors to move funds across multiple blockchains.
- A key point made:
    - *"Despite having sophisticated on-chain monitoring tools, we still lack a foolproof way to detect and prevent illicit activities before they occur."*

(c) Market Manipulation Through Algorithmic Exploits

- The speaker discusses how some financial exploits do not involve hacking but instead take advantage of market inefficiencies.
- Examples include:
    - Flash Loan Attacks: Where attackers borrow and repay large sums instantly to manipulate prices.
    - Sandwich Attacks: Where a bot front-runs a user's transaction by placing an order before and after it, manipulating the final execution price.
- These attacks do not technically break the rules but undermine the integrity of DeFi markets and harm retail users.

4. Why Current Regulatory and Compliance Approaches Are Insufficient

The speaker shifts to discussing existing compliance mechanisms and explains why they are ineffective or difficult to implement in a decentralized context.

(a) The Travel Rule for Crypto Transactions

- The Travel Rule, modeled after traditional financial regulations, requires exchanges to share customer information when transferring assets above a certain threshold.
- While this approach works in centralized financial institutions, it faces major challenges in decentralized networks, including:
    - High operational costs for exchanges to comply.
    - No way to verify self-reported wallet ownership when receiving crypto from a self-custodial wallet.
    - Privacy concerns, as user data must be shared across multiple parties.
- The speaker argues that these issues create a huge vulnerability because exchanges have no way to independently verify the information provided by users.

(b) On-Chain Transaction Analysis (Blockchain Forensics)

- Companies specializing in blockchain forensics (e.g., chain analysis firms) use advanced tracking tools to trace illicit funds.

- However, these tools have limitations:
    - They require off-chain data (such as KYC information) to be fully effective.
    - Only a few private companies have access to comprehensive data, leading to a centralization problem.
    - They excel at investigating past incidents but are less effective at preventing illicit activity in real time.
- The speaker stresses that these forensic tools do not provide protection for regular self-custodial users, who have no direct way to check the legitimacy of incoming funds.

(c) Mining Pool-Level Censorship

- Some mining pools and validators have attempted to block transactions from addresses associated with illicit activities.
- The speaker notes that this approach has received significant backlash from the blockchain community because:
    - It contradicts the core principles of decentralization.
    - It introduces subjectivity—who decides which transactions to censor?
    - It could lead to political or regulatory overreach, where miners act as gatekeepers, undermining the neutrality of blockchain networks.

5. The Need for a Different Approach: The Accountable Wallet

After discussing the limitations of current methods, the speaker introduces the Accountable Wallet as an alternative framework.

- The approach shifts the burden of proof to users, allowing them to demonstrate compliance upfront rather than relying on after-the-fact detection.
- Instead of centralized monitoring, the system enables decentralized verification, preserving privacy and autonomy.
- The speaker emphasizes:
    - *"Rather than relying on centralized controls, we need a system where users can cryptographically prove their legitimacy without exposing unnecessary personal data."*

6. Defining the Accountable Wallet

- *The Accountable Wallet is introduced as a cryptographic proof system that allows users to:*

    - *Demonstrate the legitimacy of their transactions.*
    - *Verify counterparties before engaging in financial interactions.*
    - *Ensure compliance without disclosing sensitive personal information.*
- *The speaker explains that the core idea is similar to a digital passport, where users can present credentials that prove they meet certain requirements (e.g., not on a sanctions*

list) without revealing unnecessary details.

- *Key characteristics of the Accountable Wallet:*
    - *Decentralized & User-Controlled: Users generate and manage their own proofs of legitimacy.*
    - *Privacy-Preserving: Uses cryptographic techniques to verify information without exposing personal data.*
    - *Interoperable: Works across multiple blockchains and jurisdictions, allowing seamless verification.*
    - *Flexible & Scalable: Can be adapted to various compliance and risk frameworks.*

7. The Four Core Components of the Accountable Wallet

The speaker introduces the technical building blocks of the system:

(a) Zero-Knowledge Proofs (ZKPs) for Privacy-Preserving Compliance

- *Users can cryptographically prove they meet requirements (e.g., not on a sanctions list) without revealing personal details.*
- *Example:*
    - *A person proves they are not on a blacklist without revealing their name, location, or other identity details.*
- *This ensures that regulatory requirements can be met without sacrificing user privacy.*

(b) Chain-Based Credentialing System

- *This system tracks the origin of digital assets across multiple transactions.*
- *It enables verifiable history, ensuring that assets are not tainted (e.g., proceeds from a hack or illicit activity).*
- *Instead of tracking individual coins (which could harm fungibility), the system assigns credibility scores to transactions.*

(c) Verifiable Credentials for Identity & Status Verification

- *A credentialing system allows trusted entities (such as exchanges, DeFi platforms, or regulatory bodies) to issue credentials that users can carry.*
- *Examples:*
    - *A verified investor credential could show that a user meets specific financial or regulatory requirements.*
    - *A jurisdictional credential could prove that a user is based in a compliant jurisdiction.*
- *Users can choose which credentials to share, maintaining self-sovereignty over their identity.*

(d) Trust Score Calculation

- *Transactions and credentials contribute to an ongoing "Trust Score".*

- *This score helps counterparties evaluate transaction risk before engaging.*

- *Trust Score Factors Include:*

    - *Quality of credentials attached to the wallet (e.g., verified investor status).*
    - *Transaction history (e.g., whether past transactions were with reputable entities).*
    - *Behavioral reputation (e.g., frequency of suspicious activity).*
- *The Trust Score is dynamic, meaning that bad behavior can lower it while responsible actions can improve it.*

8. Addressing Privacy & Fungibility Concerns

- *A participant asks whether this system could unintentionally harm the fungibility of cryptocurrencies.*
- *The speaker clarifies that the Accountable Wallet does NOT track individual coins.*
    - *Instead, it assesses the legitimacy of transactions and wallet behavior over time.*
- *Example given:*
    - *If a wallet receives both "clean" and "suspicious" funds, its Trust Score is calculated based on a weighted average, rather than marking specific assets as "tainted."*

9. Incentives for Adoption

- *The speaker addresses a common concern:*
    - *"If the Accountable Wallet is voluntary, why would people use it?"*
- *Answer: Economic Incentives Drive Adoption*
    - *Exchanges and DeFi platforms may require a minimum Trust Score to deposit/withdraw funds easily.*
    - *Users with higher Trust Scores could receive better trading conditions, lower fees, or faster transaction processing.*
    - *Institutional investors may only transact with verified accountable wallets, increasing demand for compliant participants.*

10. Audience Engagement: Addressing the Trust Score Calculation Concern

- *A participant raises a critical question:*
    - *"You mentioned a Trust Score. Can you explain how it is calculated?"*
    - *"Wouldn't some users try to avoid the system altogether? How do you make them use it?"*
- *The speaker acknowledges that Trust Score calculation is complex and that it is one of the most debated aspects of the Accountable Wallet framework.*

11. Trust Score: Key Principles

The speaker explains that the Trust Score is designed to be a market-driven, incentive-based system rather than a centralized compliance tool.

(a) Trust Score is Based on Three Factors:

1. *Credentials Attached to the Wallet*
    - *If a wallet has verifiable credentials (e.g., proof of KYC, regulated entity status, or jurisdictional compliance), it gains a higher baseline trust level.*
    - *Example:*
        - *A self-custodial wallet with a verified financial institution credential has a higher trust level than an anonymous, newly created wallet.*
2. *Transaction History & Provenance*
    - *The system analyzes transaction history to determine if funds come from trusted sources.*
    - *If a wallet has only received funds from reputable exchanges and high-trust-score wallets, its Trust Score remains high.*
    - *If a wallet interacts frequently with high-risk or unverified addresses, its Trust Score may decrease over time.*
3. *Behavioral Patterns & On-Chain Reputation*
    - *Trust Score can decay if a wallet interacts with suspicious or flagged transactions.*
    - *The system takes into account long-term activity rather than just one-off interactions.*
    - *Example:*
        - *If a DeFi trader interacts with a high-risk protocol associated with fraud, their Trust Score might drop slightly.*
        - *However, if they consistently engage in transparent transactions, their score stabilizes.*

12. How Trust Score Influences User Behavior

The speaker explains that users will not be "forced" to use the Accountable Wallet, but market incentives will encourage adoption.

- *Why would users care about their Trust Score?*
    - *Many DeFi platforms, exchanges, and institutional investors may start requiring a minimum Trust Score for users to access better financial services.*
    - *A higher Trust Score could mean:*
        - *Faster processing times for deposits & withdrawals.*
        - *Lower trading fees.*
        - *Better borrowing rates on DeFi lending platforms.*
        - *Access to exclusive financial services.*

- *Example:*
    - *A crypto exchange could prioritize withdrawals from wallets with high Trust Scores, reducing compliance burdens.*
    - *DeFi lending platforms could offer better collateral ratios to users with higher Trust Scores, similar to how traditional finance assesses creditworthiness.*

13. Addressing Concerns: Fungibility & Regulatory Compliance

A participant asks:

- *"If my wallet receives funds from an unknown or illicit source, does that permanently lower my Trust Score?"*

The speaker clarifies:

1. *Trust Score is not a permanent blacklist.*
    - *It can recover over time if the wallet engages in legitimate activity.*
    - *Users can prove that funds were received unintentionally and take corrective action.*
2. *Funds themselves are not "tainted"; the system evaluates wallet behavior.*
    - *Unlike traditional banking, where some funds can be "frozen", the Trust Score system avoids marking specific tokens as illicit.*
    - *Instead, it assesses wallet activity over time to provide a dynamic, reputation-based evaluation.*
3. *Different jurisdictions have different rules.*
    - *Trust Scores do not create a single global standard but instead allow users to select compliance frameworks based on their needs.*

14. Who Calculates the Trust Score?

- *A key concern is:*
    - *“Who decides what my Trust Score should be? Could this system be manipulated?”*
- *The speaker emphasizes that:*
    - *Trust Scores will be determined by an open-source algorithm, ensuring transparency and fairness.*
    - *No single entity controls the calculation, reducing centralized risk.*
    - *Users can verify their own Trust Score using cryptographic proofs, maintaining auditability.*
- *Example Given:*
    - *The Trust Score algorithm could be maintained by a decentralized governance system, ensuring that bias is minimized and the system remains fair.*

15. Incentives for Institutional & Regulatory Adoption

The speaker explains that many financial institutions and regulators are interested in the Accountable Wallet concept because it:

- *Reduces compliance costs for exchanges and DeFi platforms.*
- *Provides a market-based approach to financial integrity rather than strict enforcement.*
- *Gives regulators a tool to encourage compliance without requiring full identity disclosure.*
- *Example Given:*
    - *A crypto exchange operating in multiple jurisdictions could require a minimum Trust Score to comply with regulations without revealing private user data.*

16. What Are Zero-Knowledge Proofs (ZKPs)?

The discussion shifts from the Trust Score mechanism to the technical details of how Zero-Knowledge Proofs (ZKPs) enable privacy-preserving compliance.

- *The speaker introduces the challenge:*
    - *"How do we ensure a user is legitimate without revealing personal details?"*
    - *"How do we verify compliance without requiring centralized oversight?"*
- *Solution: Use ZKPs to allow users to prove legitimacy without disclosing private data.*
- *The speaker provides a brief explanation of ZKPs:*
    - *A cryptographic method that allows one party to prove a statement is true without revealing any details.*
    - *Example:*
        - *A user can prove they are not on a sanctions list without revealing their identity or location.*
        - *A DeFi trader can prove they meet investor qualifications without sharing personal documents.*

17. How ZKPs Are Used in the Accountable Wallet

The speaker outlines three key areas where ZKPs enable compliance:

(a) Proving Non-Membership in a Sanctions List

- *Problem:*
    - *If a wallet holder is asked to prove they are NOT on a sanctions list, they shouldn't have to reveal their identity.*

- *ZKP Solution:*
  - *A user can generate a "non-membership proof" using ZKPs.*
  - *This proves that their identity hash is NOT in a sanctions database without revealing any actual data.*
- *Example:*
  - *A trader in a DeFi protocol proves they are not sanctioned by showing a cryptographic proof instead of sharing their name.*

(b) Verifying Credentials Without Revealing Information

- *Problem:*
  - *A DeFi lending platform wants to offer better rates to verified investors but doesn't want to handle personal documents.*
- *ZKP Solution:*
  - *Users can present a ZKP proving they hold a "qualified investor" credential without revealing their name, ID, or jurisdiction.*
- *Example:*
  - *A decentralized exchange (DEX) offers higher withdrawal limits for wallets that can prove they are compliant investors.*

(c) Ensuring Transaction Legitimacy Without Disclosing Transaction History

- *Problem:*
  - *How can we track whether funds are legitimate without exposing full transaction details?*
- *ZKP Solution:*
  - *A ZKP-enabled provenance system allows a wallet to prove that its funds have not passed through illicit sources.*
- *Example:*
  - *A user can prove their funds were sourced from regulated exchanges without showing their transaction history.*

18. Addressing Potential Challenges

A participant asks:

- *"If a user can prove they are NOT on a sanctions list, what prevents them from generating a new wallet if they get sanctioned later?"*

The speaker acknowledges this as a valid concern and explains:

1. *Wallets must periodically refresh their compliance proofs.*

   - *If a user is sanctioned in the future, their wallet will lose its verifiable credentials over time.*
   - *This prevents users from using an old ZKP indefinitely to avoid detection.*

2. *Users must generate new ZKPs for each transaction.*
    - *This prevents them from using outdated proofs if circumstances change.*

19. The Role of Decentralized Identity & Verifiable Credentials

- *The speaker introduces how ZKPs work alongside decentralized identity (DID) frameworks.*
- *Decentralized identity (DID) systems allow users to:*
    - *Store credentials off-chain and prove them on-chain using ZKPs.*
    - *Control which credentials they disclose based on counterparties' requirements.*
- *Example:*
    - *A user proves they are a resident of an approved jurisdiction without revealing their country.*

20. Scaling ZKPs for Mass Adoption

- *A participant asks:*
    - *"Aren't ZKPs computationally expensive? Can this system scale?"*
- *The speaker explains:*
    - *Recent advancements in ZKP technology (e.g., zk-SNARKs, zk-STARKs) are making proofs faster and more efficient.*
    - *Batch verification techniques can reduce on-chain computational costs.*
    - *Off-chain computation with on-chain verification is a key design choice.*

21. The Role of Governance in the Accountable Wallet System

The speaker explains that governance will play a critical role in ensuring fairness, neutrality, and sustainability.

(a) Decentralized Governance vs. Centralized Control

- Option 1: Centralized Governance
    - A single authority (e.g., regulators, financial institutions) decides the rules for Trust Score calculation, credential issuance, and risk assessments.
    - Issue: This approach creates centralization risks and contradicts blockchain's decentralized ethos.
    - Risk: Could lead to subjective enforcement, censorship, and exclusion of certain users.
- Option 2: Decentralized Governance
    - A DAO (Decentralized Autonomous Organization) or similar model could manage rules and updates transparently.
    - Credential providers and stakeholders could vote on updates to the system.

    - Benefit: Ensures no single entity has control over Trust Scores or verification rules.
- The preferred model is a hybrid:
    - Regulatory input is considered, but algorithmic and community-based decision-making governs the system.
    - Similar to Ethereum Improvement Proposals (EIPs), updates to the Accountable Wallet framework could be proposed, discussed, and voted on.

22. Preventing Manipulation of Trust Scores

- A participant raises a key concern:
    - *"If Trust Scores determine access to financial services, what prevents bad actors from gaming the system?"*
- The speaker outlines three protection mechanisms:

(a) Reputation Decay & Continuous Verification

- Trust Scores are NOT permanent.
    - They decay over time to prevent users from accumulating a high score and then acting maliciously.
    - Users must regularly verify their credentials to maintain a high Trust Score.
- Example:
    - A wallet with a high Trust Score must periodically prove ongoing compliance, or its score will naturally decline.

(b) Cross-Verification of Credentials

- Credential issuers are incentivized to remain neutral and trustworthy because they are also being rated.
- If an issuer grants fake credentials, its own reputation declines, reducing the value of its credentials.
- Example:
    - A credential issuer that falsely verifies a sanctioned entity risks losing credibility, making its credentials unusable in the system.

(c) AI & Blockchain Analytics for Fraud Detection

- Advanced machine learning models and on-chain analytics can flag suspicious behavior.
- If wallets interact with known high-risk entities, their Trust Score automatically adjusts.
- Example:
    - If a DeFi wallet suddenly starts interacting with previously flagged addresses, the system detects and evaluates this change in real time.

23. Addressing Privacy Concerns in Governance

- Another participant asks:
  - *"Could this system be used for mass surveillance?"*
- The speaker acknowledges the risk and explains privacy-preserving safeguards:

(a) Verifiable but Anonymous Compliance

- ZKPs ensure that users prove legitimacy without exposing sensitive data.
- Example:
  - A wallet can prove compliance with KYC regulations without revealing name, passport details, or transaction history.

(b) Opt-In Participation & Self-Sovereign Identity

- Users can choose whether to participate in the Accountable Wallet system.
- If a wallet does not engage with compliant platforms, it remains outside the Trust Score system.
- Example:
  - A user engaging only in peer-to-peer transactions may never need to use Trust Scores.

(c) Governance Transparency & Open-Source Verification

- The Trust Score calculation algorithm and governance rules will be open-source for auditability.
- Community members can review and propose changes, ensuring fairness and adaptability.
- Example:
  - If a governance update negatively impacts a group of users, it can be challenged before enforcement.

24. Institutional & Regulatory Adoption Pathways

The speaker highlights potential adoption strategies for regulators, financial institutions, and DeFi platforms:

(a) Compliance Without Full KYC

- Regulators can enforce compliance without requiring centralized data collection.
- Example:
  - A DeFi lending platform could require Trust Scores for loans without collecting passport or social security numbers.

(b) Lowering Compliance Costs for Crypto Businesses

- Exchanges and DeFi protocols can automate risk assessment, reducing manual review costs.

- Example:
    - A DEX could automatically block flagged wallets without needing human intervention.

(c) Enabling Cross-Border Financial Services

- Because the Accountable Wallet system works across jurisdictions, it allows regulated financial access for users in multiple countries.
- Example:
    - A European DeFi protocol could recognize US-issued credentials without extra verification steps.

25. Transition to Implementation Challenges

- The discussion shifts from governance models to practical barriers in deploying the Accountable Wallet system.
- The speaker outlines key implementation concerns:
    - *“How do we ensure scalability without overloading blockchain networks?”*
    - *“What are the risks of centralization creeping into a decentralized system?”*
    - *“How can we encourage adoption by exchanges, DeFi platforms, and regulators?”*

26. Scalability Challenges in Zero-Knowledge Proofs (ZKPs)

A participant raises a concern:

- *"ZKPs sound great, but aren’t they computationally expensive? How do we scale this to millions of users?"*

The speaker explains two key scalability issues:

(a) High Computational Costs of ZKPs

- Problem:
    - Generating a ZKP requires significant computational power, making on-chain verification slow.
- Solution:
    - Move most ZKP computations off-chain, submitting only small proofs on-chain.
    - Use zk-SNARKs and zk-STARKs to compress proof sizes.

(b) On-Chain Data Bottlenecks

- Problem:
    - Storing verifiable credentials and proof history directly on the blockchain would be costly.
- Solution:

    - Use off-chain storage with cryptographic commitments.
    - Store only minimal verification data on-chain.
- Example:
    - A user's Trust Score and credential proofs could be stored off-chain, with only hashes of these credentials on-chain.

27. Addressing Risks of Centralization

- Another participant raises a key concern:
    - *"Won't this system give too much power to credential issuers? Could they control access to financial services?"*
- The speaker acknowledges this as a valid risk and presents three solutions:

(a) Decentralized Credential Issuers

- Instead of a single authority issuing credentials, multiple trusted issuers can exist.
- Users can choose from different credential providers, reducing single points of failure.

(b) User-Controlled Credentials

- Users can hold their credentials in self-sovereign identity (SSI) wallets.
- This prevents issuers from revoking credentials without justification.

(c) Transparent Credential Verification Rules

- The Trust Score formula and credential verification rules should be open-source and auditable.
- If an issuer is found to be unfairly restricting users, the community can challenge it.

28. Overcoming Adoption Barriers

The discussion shifts to real-world adoption challenges:

- *"Even if this system is great, how do we get people to actually use it?"*
- The speaker outlines three key adoption strategies:

(a) Incentives for Crypto Exchanges & DeFi Platforms

- Problem:
    - Exchanges and DeFi platforms may hesitate to adopt a new compliance system.
- Solution:
    - Offer compliance cost savings and risk reduction incentives:
        - Lower fraud risk → Lower regulatory scrutiny.
        - Faster compliance checks → Lower operational costs.
- Example:
    - A DEX offering lower fees to wallets with high Trust Scores.

(b) User Adoption Through Financial Benefits

- Problem:
  - Users may not see an immediate benefit in using the Accountable Wallet.
- Solution:
  - Offer better financial terms for verified users:
    - Lower lending rates on DeFi platforms.
    - Faster transaction approvals on exchanges.
- Example:
  - A user with a high Trust Score gets a 0.5% lower interest rate on a crypto loan.

(c) Regulatory Endorsement & Compliance Recognition

- Problem:
  - Some regulators might be skeptical of decentralized compliance systems.
- Solution:
  - Engage regulatory bodies early and demonstrate privacy-preserving compliance.
- Example:
  - A pilot program with a crypto-friendly regulator to test self-sovereign KYC.

29. Ensuring Security & Preventing Abuse

A participant asks:

- *"Could bad actors find a way to fake their credentials or manipulate Trust Scores?"*

The speaker outlines three security measures:

(a) Multi-Signature Verification

- Credential issuance requires signatures from multiple independent issuers, preventing single-point fraud.
- Example:
  - A user's KYC verification comes from three independent identity providers.

(b) AI-Powered Anomaly Detection

- Machine learning models analyze wallet behavior patterns to detect fraudulent activity.
- Example:
  - If a wallet suddenly moves large amounts of assets through privacy tools, its Trust Score is flagged for review.

(c) Revocation & Reputation Mechanisms

- If a credential issuer is caught issuing fake credentials, its reputation drops, making its credentials worthless.

30. Preparing for the Next Topic: Future Roadmap & Research Priorities

- The speaker summarizes the discussion:
    - Scalability concerns can be addressed through off-chain ZKPs and minimal on-chain data storage.
    - Centralization risks can be mitigated using decentralized credential issuers and transparent governance.
    - Adoption strategies include economic incentives, regulatory engagement, and cost savings for DeFi platforms.
    - Security concerns are managed through multi-signature verification, AI-based risk detection, and revocation mechanisms.
- Next topic:
    - The future roadmap and next research priorities for improving the Accountable Wallet framework.

31. Transition to the Roadmap Discussion

- The conversation shifts to the next steps in developing the Accountable Wallet framework.
- A speaker introduces the three major focus areas for future research and implementation:
    - *“How can we improve the efficiency and accuracy of Trust Scores?”*
    - *“What additional privacy-preserving techniques should be integrated?”*
    - *“How do we ensure real-world usability while maintaining decentralization?”*

32. Enhancing the Trust Score System

A participant asks:

- *"Can you clarify how Trust Scores will evolve over time?"*

The speaker outlines three improvements planned for the Trust Score model:

(a) Dynamic Trust Scores with More Granular Risk Assessments

- Instead of a fixed Trust Score, the system will adjust based on:
    - Transaction frequency and counterparties.
    - Type of credentials provided.
    - Interaction with high-risk wallets.
- Example:
    - A wallet that consistently interacts with low-risk, verified entities sees gradual Trust Score improvements.

    - A wallet that frequently uses privacy-enhancing tools without justification may receive additional scrutiny.

(b) Context-Aware Trust Scores

- Rather than a one-size-fits-all Trust Score, users could have different scores for different use cases.
- Example:
    - A DeFi lending protocol might use a creditworthiness-based score, while a DEX might use a transaction-risk score.

(c) Incorporating Verifiable Off-Chain Reputation Data

- The system may integrate off-chain reputation sources, such as:
    - Business credentials from financial institutions.
    - Transaction history with verified payment services.
- Example:
    - A crypto wallet linked to an established financial institution could receive a higher initial Trust Score.

33. Advancing Privacy-Preserving Techniques

A participant raises a privacy concern:

- *"If Trust Scores are public, doesn't that reveal too much information about users?"*

The speaker explains three new privacy-focused enhancements:

(a) Selective Disclosure with Zero-Knowledge Proofs (ZKPs)

- Users will be able to prove compliance without revealing full transaction details.
- Example:
    - A user can prove they meet KYC standards without sharing passport details.

(b) Multi-Layered Verification to Reduce Data Exposure

- Instead of sharing a single Trust Score, users can present only the minimum required proof for each interaction.
- Example:
    - A DEX might only require proof that a user is not on a sanctions list, rather than the full Trust Score.

(c) Time-Limited Credentials to Prevent Data Hoarding

- Credentials will expire periodically, requiring users to revalidate their information.
- Example:

    - A Proof of Clean Transaction History might only be valid for 6 months, after which it must be reissued.

34. Usability & Adoption Strategies

A key challenge is ensuring that the system is user-friendly while maintaining strong security.

(a) Simplifying User Experience (UX) for Non-Technical Users

- Problem:
    - Most blockchain users do not understand cryptographic proofs or complex compliance frameworks.
- Solution:
    - Develop intuitive wallet interfaces that automate compliance processes in the background.
- Example:
    - A wallet app could show a simple “Verified” badge, rather than exposing raw cryptographic proofs.

(b) Seamless Integration with DeFi & Exchanges

- Problem:
    - If exchanges and DeFi platforms do not integrate with the Accountable Wallet system, adoption will be slow.
- Solution:
    - Develop APIs and SDKs to allow easy integration with existing platforms.
- Example:
    - A crypto exchange could use the Accountable Wallet framework to streamline its compliance checks.

(c) Regulatory & Institutional Engagement

- Problem:
    - Regulators may resist decentralized compliance solutions if they do not understand them.
- Solution:
    - Conduct pilot programs with financial regulators to showcase the effectiveness of privacy-preserving compliance.
- Example:
    - A sandbox program with a central bank to test self-sovereign KYC solutions.

35. Research Priorities for the Next 6 Months

The speaker summarizes the top research areas that need further work before Block 13 (the next BGIN conference):

(a) Improving the Scalability of ZKP-Based Compliance Proofs

- Investigating zk-SNARKs vs. zk-STARKs for faster, more efficient proofs.
- Exploring layer 2 solutions to offload computationally expensive verification steps.

(b) Enhancing the Trust Score Calculation Model

- Refining criteria for score adjustments based on real-world risk assessments.
- Preventing Trust Score manipulation and unfair downgrades.

(c) Strengthening Governance & Decentralization Strategies

- Defining rules for credential issuance & revocation.
- Determining who governs updates to the Trust Score algorithm.

36. Addressing Remaining Questions from Participants

The session moves into an open discussion, allowing participants to raise final questions and comments.

(a) Handling Malicious Attacks on Trust Scores

A participant asks:

- *"Could an attacker manipulate the Trust Score system by sending illicit funds to innocent wallets?"*

The speaker acknowledges this as a valid attack vector and explains two possible countermeasures:

1. "Tainted Coins Don't Immediately Reduce Trust Score"
    - A wallet does not automatically get penalized for receiving funds it did not request.
    - Instead, the verification process records whether the recipient signed the transaction.
    - Example:
        - If a sanctioned wallet randomly sends crypto to an innocent user, but that user does not interact with those funds, their Trust Score remains unaffected.
2. "Funds Can Be Purged via Official Channels"
    - Users accidentally receiving illicit funds can send them to an "authorized disposal address" (such as a law enforcement-controlled address or charity fund).
    - Example:

        - If a wallet receives hacked funds, it can immediately send them to a verified recovery address to restore its Trust Score.

(b) Can Credentials Be Revoked?

Another question is raised:

- *"What happens if a user's credentials change or are revoked? Will the Trust Score reflect this?"*

The speaker outlines how credential revocation will be handled:

1. "Revoked Credentials Automatically Reduce Trust Scores"
    - If a credential (e.g., Proof of Compliance) is revoked by an issuer, the Trust Score recalculates in real-time.
2. "Verifiable Credentials Have Expiry Dates"
    - Many credentials (such as Proof of Residency or Proof of Investor Status) expire periodically.
    - Users must renew them to maintain a high Trust Score.
3. "Credential Issuers Can Flag Suspicious Users"
    - If an issuer detects fraud, they can flag the credential and prevent it from contributing to the Trust Score.

(c) Handling New Wallets with No Transaction History

A concern is raised about new wallets:

- *"How do we handle users who create a new wallet with no history? Will they start with a low Trust Score?"*

The speaker provides two solutions:

1. "Trust Score Can Be Transferred from Old Wallets"
    - A user can transfer reputation proofs from an old wallet to a new wallet using zero-knowledge proofs.
    - This allows them to maintain their credibility while using new keys for security reasons.
2. "Verifiable Credentials Can Provide an Initial Score"
    - Even if a new wallet has no transaction history, it can present credentials (such as government-issued KYC or DeFi reputation records) to start with a higher Trust Score.

37. Final Thoughts on Privacy vs. Compliance

A debate arises on balancing privacy with regulatory compliance.

- Some participants argue that requiring credentials moves too close to centralized identity systems.
- Others argue that a completely anonymous system will never gain adoption by regulators or financial institutions.

The discussion highlights three key takeaways:

1. "Users Should Control Their Own Data"
    - Users should choose which credentials to disclose based on who they are transacting with.
    - Example:
        - A DEX might only require proof of non-sanctioned status, while a DeFi lender might require additional financial credentials.
2. "Zero-Knowledge Proofs Allow Compliance Without Exposing Identity"
    - Users can prove compliance without revealing unnecessary details (e.g., proving they are over 18 without showing their exact birthdate).
3. "Compliance is a Tool, Not a Restriction"
    - A properly designed system should empower honest users rather than punish them with unnecessary bureaucracy.

38. Next Steps for the Accountable Wallet Initiative

As the session concludes, the speaker outlines the next milestones for the project:

(a) Further Research & Refinements

- The Trust Score model will be refined with more data-driven risk assessment techniques.
- Additional privacy-preserving methods will be explored to minimize data exposure.

(b) Development of a Prototype

- A technical prototype of the Accountable Wallet will be built to demonstrate real-world functionality.
- The team will collaborate with wallet providers, exchanges, and DeFi projects to test integration.

(c) Engagement with Industry Stakeholders

- The project will continue discussions with regulators, crypto businesses, and researchers.
- A proposal will be presented at Block 13 in Washington, D.C. to gather further feedback.

39. Closing Remarks & Future Collaboration

- The session moderator thanks all participants for their contributions.
- Attendees are encouraged to join bi-weekly working group meetings to stay involved.
- The session ends with a reminder to continue discussions in upcoming industry forums.

Financial Stability in Decentralized Finance

Materials: 【Day 2 16:30-18:00 Room B】Benjamin_Restaking_Paper.pdf
【Day 2 16:30-18:00 Room B】Leveraged Stakings and its Financial Stability Risk.pptx
【Day 2 16:30-18:00 Room B】2024-12-11 Benjamin Kraner - Restaking Networks.pptx

- Purpose of the Session:
    - Introduce the concept of liquid staking, restaking, and liquid restaking to traditional finance experts, and highlight financial stability risks associated with these leveraged staking mechanisms in decentralized finance (DeFi).
    - Understand how these risks could propagate from DeFi to traditional financial systems and identify the next steps for further research.

1. Foundational Concepts Clarified:

- Explanation of Liquid staking (LSTs):
    - Traditional staking on Ethereum requires 32 ETH, but protocols like Lido allow users to stake smaller amounts and receive a liquid staking token (LST) such as stETH in return.
    - Liquid staking protocols aggregate user deposits and delegate them to Ethereum validators. Users retain liquidity via LSTs, which can be traded or used in DeFi.
    - Lido and EigenLayer are separate. While Lido issues LSTs like stETH, EigenLayer introduces restaking. Users can restake native ETH or stETH on EigenLayer to secure additional services (AVSs).
- Explanation of Restaking:
    - Restaking allows staked ETH (which is normally idle) to secure other protocols, increasing capital efficiency.

    - Validators (operators) give control of their withdrawal credentials to EigenLayer, enabling slashing enforcement across multiple protocols (AVSs).
    - Operators register with AVSs (Actively Validated Services) and agree to their slashing conditions. AVSs get economic security from staked ETH. Misbehavior (e.g., providing bad oracle data) can result in slashing.
    - Risk associated with restaking includes:
        - Economic Security Risks: If operators are slashed by one AVS, they lose ETH staked on Ethereum, which could impact multiple protocols they support.
        - Complex Slashing Conditions: Currently, most AVSs don't have clear slashing rules, making it hard to quantify or anticipate risk.
        - Reward Misalignment: Operators may choose AVSs based on token incentives rather than technical fit or safety, creating potential systemic risks.

- Liquid restaking:
    - Even restaked assets can be tokenized, creating *liquid restaking tokens (LRTs)* that can be traded or reused, compounding complexity and leverage.

2. Economic Security Model of Restaking:

- EigenLayer mediates slashing: if an operator misbehaves on any AVS, EigenLayer may *slash their ETH*, preventing withdrawal or reducing payout. This mechanism enables AVSs to *enforce accountability* without having to bootstrap their own security. However, slashing conditions are not fully implemented yet, so current analysis remains partly theoretical.

3. Risks Highlighted in Restaking Model:

- Cascading risks:
    - A slashing event in one AVS may cause loss of validator funds, which affects their ability to secure other AVSs. The *entire economic security structure* can be undermined through domino-like failures.

- Network structure:
    - Operators tend to *subscribe to multiple AVSs* to maximize rewards, creating a *bipartite graph*. Sparse graphs (low AVS participation) reduce security, while dense graphs (high participation) increase slashing exposure.

- A participant presented a *simulation* showing how these cascading failures can propagate in the restaking network based on actual data. An operator failure can lead to slashing in multiple AVSs, which in turn affects other operators, creating a chain reaction.

- Users can get LSTs and liquid restaking tokens (LRTs), which can be used as collateral in DeFi.
  LSTs and LRTs can be reused in lending protocols, creating leverage. If token prices fall (e.g., due to slashing), mass liquidations may occur. LSTs may lose peg, triggering liquidation cascades and affecting the broader DeFi ecosystem.

4. Comparison to Traditional Finance:

- Operators were likened to *brokers*, and EigenLayer to a *clearing house* or *insurance system*. One analogy: operators take credit risk like brokers do, while EigenLayer guarantees enforcement like a clearing house. However, restaking adds complexity via *token reuse* and *stacked leverage*, similar to *rehypothecation* in TradFi.

- This sparked discussion on whether these analogies can help *quantify risk* and how *portfolio theory* (e.g. Markowitz optimization) may apply to operator decisions. A participant noted the difficulty in quantifying both risk and reward due to lack of real-world lashing events and off-chain governance.

5. Slashing Correlation and Systemic Risk:

- Debate emerged on *how correlated slashing events* across AVSs could be:

  - Some argued they are *idiosyncratic* since slashing is tied to specific misbehavior (e.g., wrong price feed in an oracle AVS). Others warned that *infrastructure failure* (e.g., AWS downtime affecting many validators) could lead to *mass slashing*.

- Ethereum's slashing rules are *highly specific* (e.g., double-signing) and downtime doesn't typically result in slashing—mitigating some correlation concerns. Slashing is designed to be narrowly targeted in general, reducing likelihood of contagion.

- Still, the possibility of unexpected correlation spikes (like during the 2008 housing crash) was raised as a valid risk research area. Some voiced concern that unknown risks could lead to correlated slashing events, analogous to the 2008 housing crisis.

6. Propagation to Traditional Finance:

- Concern raised: if only DeFi is impacted, regulators may not act—but *DeFi risks can propagate* to TradFi. For example, ETH ETFs or staking services offered by TradFi could expose investors to *underlying risks* they don't understand. Collapse of LST prices could

affect lending protocols, which could indirectly affect centralized entities with DeFi exposure.

- Agreed on the need to map these interconnections to quantify potential systemic risk spillovers.
- A study was cited estimating that leveraged staking strategies have an *average multiplier of 3.5x* and APR of ~6% (2020–2023). Discussion explored whether APRs from staking were *correlated with interest rate environments*:
    - So far, ETH staking yields appear *independent* from macro rates—driven more by *validator count* and *network activity*. APR growth seems to have plateaued at ~3%, slowing new staking inflows.

7. Preventative Measures & Ethereum Foundation's Role:

- Question raised: are *any preventative controls* in place in DeFi or Ethereum to limit LSD/LRT risk propagation? Answer: measures exist *within specific protocols*, but no *ecosystem-wide mitigation framework* yet. Preventive design (e.g., caps on collateralization) would have to be protocol-specific. Ethereum Foundation hasn't taken official action on EigenLayer yet.
- The Ethereum Foundation reportedly considered protocol changes (e.g., disallowing smart contracts as withdrawal addresses), but these weren't implemented.
    - Ethereum governance may step in if slashing from AVSs threatens ETH consensus.
    - There were internal discussions (e.g., Justin Drake's talk) on whether to prevent smart contracts from being withdrawal addresses—a way to prevent EigenLayer-like restaking.
    - One concern was that *Ethereum may avoid restrictive action* for fear of driving users to other PoS chains like Solana or BNB Chain.

8. Next Steps:

- There was a call for deeper research, possibly by BGIN or affiliated universities, to:
    - Quantify risks in leveraged staking and restaking.
    - Identify potential amplification mechanisms.
    - Track the interlinkages between DeFi and TradFi, especially through derivative tokens and staking-based financial products.

- The conversation ended with recognition of the importance of cross-disciplinary collaboration between DeFi researchers, traditional finance experts, and regulators to build a comprehensive understanding of the risks and rewards of these evolving technologies.